

EGAS Promotion & Secondment Workflow System

Final Requirements & System Architecture

Freeze

Version 2.0 - FINAL Implementation Baseline

15 August 2026

Item	Authoritative value
Status	Requirements-analysis freeze for Codex implementation
Supersedes	v1.7 consolidation pages, v1.8 open-items review addendum, schema v0.1-v0.8 where conflicting
Database baseline	PostgreSQL logical schema v1.0 FINAL (separate artifact; CAP CDS/migrations become implementation authority)
UI context	EGAS_UI_CONTEXT_v1.4_Final.md + approved DESIGN.md/shell + approved screen handoffs
Security target	Backend-enforced authorization; OWASP ASVS 5.0 Level 2 target for production-intended build

AUTHORITATIVE PRECEDENCE

The v2.0 pages at the beginning of this PDF override any conflicting wording in the appended v1.7 baseline. Non-conflicting v1.7 requirements remain in force. Codex must use schema v1.0 FINAL, UI_CONTEXT v1.4 FINAL, and approved UI handoffs alongside this document.

FINAL CONFIRMATIONS INCLUDED

P1/S1 Employee Affairs and P2/S2 Organization are the visible mandatory signer blocks; P5/S5 can view/print/download the final form; every workflow actor has immutable View as PDF for the data received; one account may hold multiple roles under one active role at a time; and workflow notes are append-only with all candidate notes printed chronologically in ملاحظات.

1. Final decisions resolved after the v1.8 review

Open item	Final decision / correction	Implementation effect
Missing employee الإدارة / التبعية التنظيمية	The authoritative annual eligible workbook does not provide these employee-level fields. v1 must not infer them from النيابة . Proposed secondment organizational dependency remains a manual Organization field.	No fabricated employee field; keep manual secondment dependency input.
"10" sentinel	Actual current workbook uses blanks. Normalize blank/whitespace to NULL. Also accept literal trimmed "10" as NULL only for backward compatibility with the stakeholder instruction if encountered later.	Importer handles real data correctly and remains tolerant.
Unmapped routing labels	Unknown source routing labels are blocked per employee until explicitly mapped to an approved routing unit or a new unit is formally approved. No fuzzy/automatic guessing.	Add routing-unit source-alias mapping; does not block coding of the whole system.
Authority workbook	Reference-only. It must not auto-create accounts, roles or authority assignments.	Operational accounts and authority mappings remain manual Admin configuration.
Excel schema validation	Validate required header names before staging. Match by header name, not fragile fixed column position.	Wrong workbook/missing/duplicate headers are rejected early.
SAP/Fiori BRD mismatch	For v1 the confirmed stakeholder decisions supersede direct SAP HCM integration and SAP-Fiori-platform hosting. Annual approved Excel snapshot + standalone internal web app remain the implementation baseline.	Trace deviation explicitly; written organizational re-confirmation is recommended before formal UAT/production acceptance.
Schema signoff/month fields	Confirmed present conceptually, now explicitly included in schema v1.0 FINAL and architecture delta.	No stale ER-model ambiguity.
Visible signoff stage	EA visible block = P1/S1 initial signoff; Organization visible block = P2/S2 initial signoff, from the final completed iteration.	Later approvals do not replace the official-form signer blocks.
View as PDF - every workflow actor	Every operational actor can open an immutable official-form PDF snapshot of exactly the data they received at their task/stage. Fields owned by later stages remain blank.	Received-stage PDFs never change after later edits; current draft/final PDF actions are separate.
Per-candidate notes	Any workflow actor can append notes/messages. Every candidate-level note appears in the official ملاحظات column in chronological order; request-level notes remain workflow messages/history. All authorship/stage/time is audited.	Append-only workflow_note model.
Level-1 eligibility	The supplied annual workbook is already the eligible v1 population.	No second eligibility engine is invented.
Multi-role users	One human account may hold multiple roles. One active role at a time controls navigation and authorization.	Replace single user.role with user_account_role mapping; active role is audited.

2. Final workflow stage model and signoff semantics

2.1 Promotion

Stage	Actor	Primary responsibility	Official-form signoff effect
P1	Employee Affairs	Create request, set form month/year, lookup/add eligible employees, review snapshot data, add notes, sign and submit.	Mandatory EA signoff. This is the EA block displayed in the official form.
P2	Organization	Claim request, review/prepare Organization data, add notes, sign and submit.	Mandatory Organization signoff. This is the Organization block displayed in the official form.
P3	Employee Affairs	Review Organization data and approve forwarding, or use permitted return/rejection	Audit/workflow approval only; does not replace P1 signer.

		actions.	
P4	Approving Authority	Per employee choose same-position or other-position promotion; manually type target job when other-position; notes/approve/reject/return.	Decision appears in form; no new visual signature block unless EGAS later supplies an official template requiring one.
P5	Employee Affairs	Final confirmation/approval; view, print and download frozen final official PDF.	Final approval recorded in audit; visible EA block remains P1 signer.

2.2 Secondment

Stage	Actor	Primary responsibility	Official-form signoff effect
S1	Employee Affairs	Create request, set form month/year, lookup/add eligible employees, review snapshot data, add notes, sign and submit.	Mandatory EA signoff. This is the EA block displayed in the official form.
S2	Organization	Claim request; choose form subsection; enter unlimited proposed positions and organizational dependencies; choose مستوفي/غير مستوفي ; add notes; sign and submit.	Mandatory Organization signoff. This is the Organization block displayed in the official form.
S3	Approving Authority	Review Organization proposals and choose exactly one proposed position per employee; notes/approve/reject/return.	Decision appears in form/audit; no authority signature block in current official form.
S4	Organization	Post-authority review/confirmation; cannot silently replace authority selection; notes/return/reject as permitted.	Audit/workflow approval only; visible Organization block remains S2 signer.
S5	Employee Affairs	Final confirmation/approval; view, print and download frozen final official PDF.	Final approval recorded in audit; visible EA block remains S1 signer.

Mandatory signature rule: P1/S1 and P2/S2 cannot be submitted without an authenticated signer name, per-signoff job-title value, and a valid immutable signature asset. The signer name defaults from the account and cannot be manually changed; the job title defaults from profile but may be overridden only for that signoff.

3. View as PDF, draft PDF, and final PDF

3.1 View as PDF for every workflow actor

- Employee Affairs, Organization, and Approving Authority each have a View as PDF action for workflow tasks they receive.
- The action renders the official form using an immutable stage-received snapshot captured when that actor actually receives the task. For an Organization shared queue, capture occurs when the request is claimed; for directly assigned stages, capture occurs when opened/assigned.
- The PDF shows exactly the business data available at receipt time. Later edits by later actors do not change the actor's historical received-stage PDF view.
- Fields owned by later stages remain blank, preserving the official form structure.
- Authorized users can reopen their own received-stage PDF snapshots from request history/timeline after completing the stage.

3.2 Draft and final official form

- At P1/S1, Employee Affairs can preview, print, and download a draft official form while preparing the request. Later-stage fields are blank.
- At P5/S5 final confirmation, Employee Affairs can view, print, and download the frozen final official form.

- The final PDF uses the final completed iteration and freezes request, candidate, decision, visible signoff, and printed-note data. Later profile/signature changes cannot alter it.
- Employee Affairs and Organization signatory blocks appear on one horizontal row. EA uses P1/S1 signoff; Organization uses P2/S2 signoff.
- Audit-log PDF remains a separate printable/downloadable document.

4. Workflow notes/messages

- Any operational workflow actor may append a note/message at their stage.
- Notes are append-only. One actor cannot overwrite another actor's prior message.
- Every note records author account, active role, stage/task, server timestamp, request/iteration, and optional candidate scope, and creation is recorded in the audit log.
- Request-level notes act as messages to subsequent actors and appear in workflow history/message UI.
- Every candidate-level note is part of the official candidate record and renders in the candidate ملاحظات column in chronological order. There is no print/include toggle, and no actor can overwrite a previous actor's note.

5. Multi-role account model and manual account creation

- One human/staff identifier maps to one application account. The same account may hold multiple roles: Admin, Employee Affairs, Organization, and/or Approving Authority.
- Roles are manually granted/revoked by authorized Admin users. No staff spreadsheet auto-creates roles or accounts.
- The first privileged Admin is created only by the controlled bootstrap command. There is no public Admin registration.
- Admin Portal accepts accounts with active Admin role. Workflow Portal accepts active operational roles. If more than one operational role exists, the user selects an active role and may switch roles through an explicit role switcher.
- Authorization is evaluated only under the active role. Permissions from multiple assigned roles are never silently unioned for a single action.
- Every workflow action, claim, note, signoff, and security-sensitive operation records the active role snapshot in audit/security evidence.
- A user may legitimately hold Admin and operational roles; v1 does not impose a blanket segregation-of-duties prohibition because the stakeholder confirmed multi-role staff. Admin privileges themselves never authorize operational workflow actions.

6. Annual Excel import and routing data rules

Rule	Final requirement
Authoritative dataset	البيانات الأساسية is the annual eligible operational population for v1. The broader company workbook is not used to decide eligibility.
Expected headers	Validate the required business header names before staging. Match values by header name; do not rely on fixed column order.
Blank normalization	Trim strings; blank/whitespace performance rating and routing-unit values become NULL. Literal "10" also becomes NULL if ever encountered.
Personnel Number	Required and unique within annual batch; employee identity remains stable while annual snapshot is keyed by year + personnel number.
Unknown routing labels	Block the affected row from workflow activation until an explicit source-label alias maps it to an approved routing unit or EGAS formally adds a new unit.
No inferred employee administration	Do not fabricate employee التبعية التنظيمية or الإدارة from النياية. Those fields are absent from current authoritative source.
Secondment dependency	The organizational dependency of each proposed secondment position is manually entered by Organization.
Authority workbook	Reference-only; never parsed to grant permissions or auto-create Approving Authority accounts.
Import UI	Admin/operator sees validation totals, blocked rows, warnings, unmapped source labels, and explicit activation action.

Known 2026 data-setup issue: the annual workbook currently contains source routing labels that do not resolve to the approved 22-item reference list. These rows remain blocked until EGAS supplies an explicit mapping/correction. This is a pilot data-setup task, not permission to guess mappings or automatically expand the routing-unit list.

7. Final security additions

7.1 Signature asset hardening

- Accept only authenticated, authorized PNG/JPEG signature uploads; validate actual decoded image structure rather than trusting extension/MIME.
- Enforce compressed file-size and decoded pixel/dimension limits to resist decompression bombs/polyglots.
- Decode and re-encode to a canonical server-generated image, stripping EXIF/metadata; store outside web root under opaque keys.
- Serve signature images only through authorization-checked endpoints with server-controlled Content-Type and Content-Disposition plus nosniff.
- Freeze the canonical SHA-256 into the workflow signoff so historical substitution is detectable.

7.2 PDF renderer isolation

- Headless Chromium/PDF rendering is a separate trust boundary: no arbitrary internet/internal-network egress and no uncontrolled file:// access.
- PDF templates load only approved local/template assets; all user-entered text is inserted as encoded text, never raw HTML/template concatenation.
- Apply per-user PDF/report generation throttling and bounded renderer concurrency in addition to ordinary API rate limits.

7.3 Time, SAST, and active-role security

- Pilot/production hosts use EGAS-approved synchronized server time/NTP. Workflow, signoff, audit and security timestamps always use server time, never browser time.
- Run SAST against custom CAP/React code before pilot/release, in addition to dependency scanning, secret scanning, lint, tests and build.
- For multi-role users, backend authorization and optional RLS context use the selected active role; automated tests must prove role permissions are not unioned.
- Except for one-time bootstrap, users cannot grant/revoke their own roles, grant themselves Manage-Admins, configure themselves as an Approving Authority, or delegate an authority assignment to themselves; a different authorized Manage-Admins account performs those privileged changes.

All previous v1.6 security requirements remain in force: secret isolation and Git purge/rotation response, adaptive password hashing, secure session cookies, server-side authorization, IDOR protection, CSRF/CORS, validation, parameterized queries, XSS/output encoding, response allow-lists, upload restrictions, HTTPS, security headers, storage/backup encryption, rate limiting/anti-bot controls, append-only/tamper-evident audit, least-privilege database access, RLS as defense-in-depth where safely integrated, safe errors, dependency/secret scanning, and security tests.

8. PostgreSQL / CAP data-model delta - schema v1.0 FINAL

Entity/change	Purpose
user_account_role	Many-to-many role assignment; one human account can hold multiple roles. Manage-Admins privilege belongs to Admin role assignment.
auth_session.active_role	Explicit role context used for navigation, authorization, audit and RLS context.
routing_unit_source_alias	Explicit mapping of source workbook labels to approved routing units; no fuzzy inference.
import_batch header metadata	Record header validation/detected headers before staging/activation.
stage_task.claimed_role_snapshot	Preserve active role that claimed/owned the task.
stage_received_snapshot	Immutable JSON/hash/template snapshot used by View as PDF for exactly the data an actor received.
workflow_note	Append-only request/candidate messages with author role. All

	candidate-level notes print chronologically in ملاحظات; request-level notes remain in workflow/audit history.
stage_action.actor_role_snapshot	Unambiguous evidence for multi-role users.
workflow_signoff.signature_sha256_snapshot	Freeze exact canonical signature hash in signoff evidence; initial EA/ORG signature mandatory.
pdf_generation_log RECEIVED state	Distinguish received-stage PDF, draft current form, final frozen form, and audit PDF.

9. Original BRD technical requirements traceability

BRD technical item	v2.0 disposition
1. Execute service completely on SAP Fiori platform	SUPERSEDED for v1 by confirmed standalone internal web-app decision. UI remains enterprise/Fiori-inspired; implementation uses React + TypeScript/UI5 components and CAP backend.
2. Direct data connection to SAP HCM	SUPERSEDED for v1 by confirmed annual full Excel snapshot import into PostgreSQL. No live SAP integration in pilot.
3. Automatic retrieval using Personnel Number	IMPLEMENTED against the approved annual PostgreSQL snapshot rather than live SAP.
4. Multi-stage workflow across departments	IMPLEMENTED with separate Promotion and Secondment state machines including return/restart/cancel/audit behavior.
5. In-system notifications on stage movement	IMPLEMENTED as in-app notifications; no email dependency required for v1.
6. Search current and previous requests	IMPLEMENTED with role-scoped search/history and request/audit access.
7. Print form as PDF	IMPLEMENTED with stage-received View as PDF, P1/S1 draft, P5/S5 final frozen PDF, and separate audit PDF.
8. Complete Audit Log	IMPLEMENTED as append-only/tamper-evident workflow/security evidence with printable audit reporting.

Governance note: Because items 1 and 2 reverse signed BRD technical wording, written re-confirmation from the appropriate EGAS owner is recommended before formal UAT/production acceptance. This is a governance/acceptance task; it does not change the confirmed pilot architecture.

10. Additional acceptance criteria introduced by v2.0

- P1/S1 initial Employee Affairs stage cannot submit without a valid signature signoff; signer full name is account-derived and job title is defaulted with signoff-only override.
- P2/S2 initial Organization stage cannot submit without a valid signature signoff.
- Final official PDF uses P1/S1 Employee Affairs and P2/S2 Organization signatory blocks from the final completed iteration and displays them on one horizontal row.
- P5/S5 Employee Affairs can view, print and download the final frozen official PDF.
- Every workflow actor can View as PDF for a task they received, and that received-stage view remains unchanged after later workflow edits.
- Multi-role users can switch only among assigned roles; every protected action is authorized under one active role and tests prove no permission union.
- Workflow notes are append-only, attributable and audited; all candidate-level notes appear chronologically in the official Notes/ملاحظات area without overwriting previous authors.
- Importer rejects a wrong/malformed workbook before staging when required headers are missing/duplicated; it maps by header name and normalizes blank/whitespace values to NULL.
- Rows with unmapped routing labels cannot enter workflows until explicitly mapped; the application does not guess or silently add routing units.
- Signature uploads pass decode/re-encode, metadata stripping, type/size/pixel checks and authorization-checked serving.
- PDF renderer is network/file isolated from arbitrary external resources and user content cannot inject raw HTML/URLs.
- Pre-pilot security gate includes SAST plus dependency/secret scans and server time synchronization check.

11. Final handoff package and precedence for Codex

Priority	Artifact	Rule
1	This v2.0 Final Requirements & Architecture Baseline	Business rules, workflows, security, acceptance, technical corrections. v2.0 front pages override appended v1.7 conflicts.
2	EGAS_PostgreSQL_Logical_Schema_v1.0_Final.sql / resulting CAP CDS migrations	Data-model baseline; once implemented, CAP CDS/migrations become implementation schema authority.
3	EGAS_UI_CONTEXT_v1.4_Final.md	UI-specific business/interaction rules including multi-role, notes, View as PDF and signoff stages.
4	DESIGN.md + approved shared shell	Visual design system only.
5	Approved screen image + completed handoff .md	Exact screen intent, fields, actions, dialogs, role context and PDF implications.
6	AGENTS.md + final Codex implementation prompt	Permanent repository coding rules and task sequencing; may not override higher-priority business rules.

Do not give Codex the v1.8 open-items review addendum as an authoritative requirements source. It is a review artifact. The legitimate findings are resolved in these v2.0 pages; obsolete/incorrect findings are not implementation requirements.

12. Remaining pre-pilot setup items (not unresolved implementation logic)

- EGAS must explicitly map/correct the currently unmapped source routing labels before those affected employees are used in a real workflow.
- Admin manually creates real operational accounts and grants the confirmed role combinations; real staff identifiers are intentionally absent from documentation, source seeds and UI-generation assets.
- Admin configures one active primary Approving Authority assignment for each approved active routing unit before pilot preflight passes.
- Written organizational re-confirmation of the standalone/Excel descope from signed SAP Fiori/SAP HCM BRD items is recommended before formal UAT/production acceptance.
- The source/meaning of the legacy "تقرير آخر ترقية" field remains a business-data item if EGAS wants it populated beyond the current manual/configurable treatment; it does not block core workflow implementation.

13. Incorporated baseline

The detailed SRS v1.6 and System Architecture v1.6 pages carried inside the former v1.7 baseline are appended after these v2.0 correction/freeze pages. The obsolete v1.7 consolidation/front pages are intentionally omitted to reduce conflicting instructions. Where any appended wording differs, these v2.0 pages control.

EGAS

Software Requirements Specification -
Promotion & Secondment Workflow Website

Version 1.6 Draft - Security Hardening Update

Document Version	1.6 Draft
Date	15 August 2026
Update Type	Security hardening and secure implementation baseline
Applies To	All v1 functional, API, database, repository, pilot and deployment behavior
Precedence	This v1.6 update supersedes any weaker or conflicting security wording in the embedded v1.5 body.

Authoritative amendment rule

The original v1.5 body is retained for traceability. The security section appended after that body is part of this v1.6 document and is authoritative for Codex implementation, testing, repository policy and pilot/production deployment. Where the older body is silent, the appended security baseline applies. Where a conflict exists, the stricter v1.6 security requirement applies.

Important architecture clarification

The browser shall never receive a PostgreSQL username, password, connection string, service-role credential or so-called public database key. All database access remains backend-mediated. PostgreSQL Row Level Security (RLS) is defense-in-depth and does not replace server-side authorization.

EGAS

Software Requirements Specification

Promotion & Secondment Workflow Website

Document Version	1.5 Draft
Status	Updated baseline: manual operational accounts/authority mapping, BRD role input/output reconciliation, simplified annual Excel import
Primary Language	English specification; product UI defaults to Arabic (RTL)
Prepared For	Egyptian Natural Gas Holding Company (EGAS)
Date	15 August 2026

Source baseline: original 6-page BRD + confirmed stakeholder interview answers + annual eligible HR dataset + final printable forms + approved UI/handoff decisions. The النواب والمساعدین workbook is reference material only; v1 does not infer accounts or routing authority from its inconsistent job-title text.

Revision Control

Version	Date	Status	Description
0.1	13 Aug 2026	Working	Initial requirements register prepared from BRD.
1.0	14 Aug 2026	Draft baseline	Reconciled BRD, stakeholder interview answers, dataset and final printable forms.
1.1	15 Aug 2026	Draft update	Added first-Admin bootstrap, Manage Admins permission and protected Admin-to-Admin account management.
1.2	15 Aug 2026	Draft update	Integrated Google Stitch as UI design source and portable PC-to-laptop pilot assumptions.
1.3	15 Aug 2026	Draft update	Added private GitHub repository/Codex handoff contract, AGENTS.md and stable pilot command interface.
1.4	15 Aug 2026	Draft update	Added authority-directory workbook, corrected 22-unit routing model from distinct Deputies to configurable Approving Authority/Assistant approving authorities, formalized form-section/drop-down/manual-entry controls and revised PostgreSQL requirements.
1.5	15 Aug 2026	Draft update	Reconciled original BRD role inputs/outputs; made all operational accounts and Approving Authority mappings manual Admin configuration; removed authority-workbook import as an application dependency; clarified direct XLSX import script.

Document Map

1. Introduction
2. Scope and System Context
3. Roles and Access Model
4. Business Rules
5. Functional Requirements

5.7 BRD Role Input / System Return Reconciliation

Original BRD baseline - Employee Affairs input: create the worksheet/form and enter Personnel Number(s). System return: retrieve employee master fields automatically, including personnel number, name, current job, job level, organizational data/routing unit, latest annual performance report and original qualification/date fields available in the approved annual dataset. The BRD also states the routing unit is determined automatically from Personnel Number.

Original BRD baseline - Organization input for secondment: add the suitable vacant position(s) for each employee. The supplied final form clarifies that Position Title and Organizational Dependency are manual text fields and Qualification Compliance is a controlled **مستوفي / غير مستوفي** value. Organization then sends the request forward.

Original BRD baseline - Approving role input for secondment: review the proposed vacancies and select exactly one position for each employee using a single-choice control; then submit. Confirmed stakeholder rules additionally allow Reject or Return for Correction with a mandatory reason.

Promotion correction from stakeholder interview: although the original BRD describes the same/other-position choice on the Organization screen, the confirmed routing assigns the final Same Position / Other Position decision to the Approving Authority. When Other Position is chosen, the target job title is entered manually. Organization therefore reviews/prepares the promotion request, Employee Affairs performs the confirmed middle review, and the Approving Authority makes the final promotion-position choice.

Final Employee Affairs return: after the downstream stages, Employee Affairs receives the completed decisions, performs final approval, and the system freezes the approved request and generates the redesigned final PDF. Finalization does not update the annual HR master snapshot.

6. Workflow Specifications
 7. Data and PostgreSQL Requirements
 8. Search, Reporting and PDF Requirements
 9. Security Requirements
 10. Non-Functional Requirements
 11. UI/UX and Accessibility
 12. Deployment and Operations
 13. Testing Requirements
 14. Delivery Phases
 15. Acceptance Criteria
 16. Open Items and Engineering Baselines
 17. Traceability and References
- Operational user identifiers are entered manually through Admin account management and are not embedded in this specification or repository seeds. The first Admin remains the only bootstrap-created operational account; all later Admin, Employee Affairs, Organization and Approving Authority accounts are created manually and audited.
18. Implementation Handoff and Repository Contract

1. Introduction

1.1 Purpose

This SRS defines the functional, workflow, data, security, user-interface, reporting, PDF, deployment and quality requirements for the EGAS Promotion & Secondment Workflow Website. It is intended to be the primary baseline for engineering, UI/UX, testing, internal deployment and stakeholder acceptance.

1.2 Product Objective

- Digitize the two paper-driven first-level-and-below workflows for secondment (ندب) and promotion (ترقية).
- **Route department-based forms through Employee Affairs, Organization and the responsible Approving Authority (Deputy/Assistant) with complete traceability.**
- Use an annually supplied SAP-derived Excel snapshot imported manually into PostgreSQL; no SAP integration is required in v1.
- Produce a redesigned Arabic final form containing the approved business information and approvals, plus a separate printable audit-log PDF.
- Operate as an internal, Arabic-first web application on the EGAS network with role-based access and in-app notifications.

1.3 Definitions

Term	Meaning
Employee Affairs	شئون العاملين - creates requests, receives returns, performs final approval.
Organization	إدارة التنظيم - claims assigned work, enters/reviews organization-controlled information and proposed secondment positions.

Term	Meaning
Approving Authority	النائب / المساعد المختص - the configured executive approver for a routing unit. The person may hold a Deputy, Assistant, acting-Deputy or acting-Assistant title.
Routing Unit / النيابة أو المساعد	One of the 22 top-level workflow routing units used by the forms. A unit is routed to its active approving-authority assignment.
Worksheet / Form	A promotion or secondment request containing one or more employees from the same department.
Iteration	One pass through the workflow. Restart creates a new iteration without deleting prior history.
Annual Snapshot	Full employee dataset supplied once each year, nominally on 1 July, and imported into PostgreSQL.
Authority Directory	Controlled staff-reference data loaded from النواب والمساعدین.xlsx. It contains candidate staff records but is not itself the approved 22-row routing map.
Form Section / Job Category	A drop-down-selected subsection in the printable form, e.g. وظيفة مدير إدارة or وظيفة رئيس قسم. Multiple candidates may belong to the same section.

1.4 Source Precedence

Baseline rule: Where the original BRD and later stakeholder answers differ, the confirmed stakeholder interview answers in S2 take precedence. The sample SRS S5 is used only as a documentation pattern.

2. Scope and System Context

2.1 In Scope for v1

- Promotion and secondment workflows only.
- **Local application accounts for Admin, Employee Affairs, Organization and Approving Authority users.**
- **Separate Admin Portal plus a Workflow Portal with role-specific screens for Employee Affairs, Organization and Approving Authority.**
- Annual full-snapshot Excel import into PostgreSQL through a controlled technical import procedure.
- Request creation, employee lookup, grouping by department and job category, stage claiming/assignment, review, approvals, rejection, return, cancellation, recall and restart.
- In-app notifications, immutable/tamper-evident audit history, search/history, operational dashboards and PDF generation.
- Arabic RTL interface on Chrome, Firefox and Edge for laptop/desktop screens; WCAG 2.2 Level AA target.

2.2 Out of Scope for v1

- Live SAP HCM integration, direct SAP database access, OData/RFC/BAPI integration, or writing results back to SAP.
- Active Directory/SSO authentication; the architecture shall allow future replacement of local authentication.
- Public Internet access, mobile application, employee self-service, or employee participation in approval decisions.
- Automatic vacancy sourcing or automatic job-description eligibility calculation.
- Email notifications; v1 notifications are in-app.
- Production-grade disaster recovery/high availability beyond the pilot baseline until EGAS IT defines the production standard.

2.3 Context

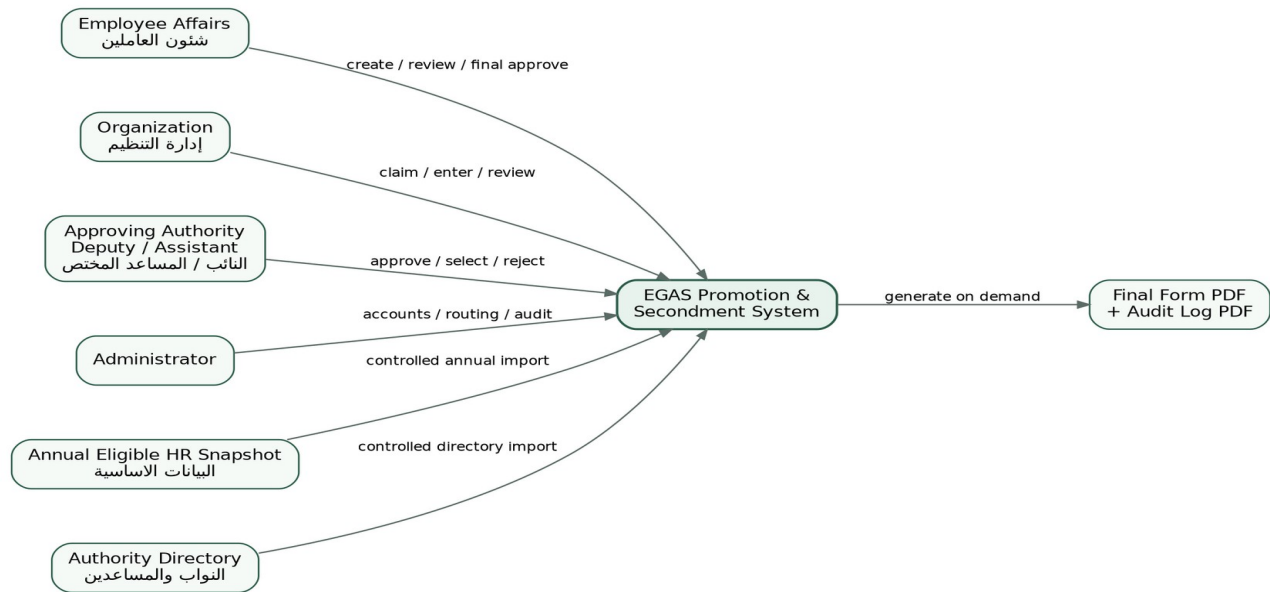


Figure note: v1.5 uses the term Approving Authority for the responsible Deputy/Assistant. Operational authority accounts and routing-unit mappings are configured manually by Admin; job-title text is descriptive only and is never used to infer authorization.

Figure 1 - v1 system context and primary actors.

2.4 Dataset Context

The annual workflow workbook (1) البيانات الاساسية.xlsx remains the authoritative eligible employee population for the 2026 cycle. The broader staff/authority workbooks may be consulted as reference material, but v1 does not import them to create application accounts or infer an Approving Authority from a job title. Admin creates all Employee Affairs, Organization and Approving Authority accounts manually and explicitly assigns roles/routing units.

Data-cleaning decision: The literal source value “10” in the performance-report field and in the department field shall be treated as NULL during import, per stakeholder instruction. Missing or unmapped data shall be visible in an import validation report rather than silently invented.

3. Roles and Access Model

Role	Permissions / Scope
Administrator	Separate Admin Portal. Create/edit/deactivate users; reset passwords; assign roles; manage routing units and approving-authority assignments; create/disable temporary authority delegations; import/curate authority-directory data; view system-wide audit/search/reports. The first privileged Admin is created by controlled bootstrap; only Admins with Manage Admins may create/manage other Admins. Cannot rewrite audit history.
Employee Affairs	Create promotion/secondment forms for a department, add employees, submit, view status of own requests, receive all returns/rejections/recalls for own requests, correct/restart/cancel, perform defined review stage in promotion, and final approve.
Organization	See unassigned Organization work queue; atomically claim a request; other Organization users see who claimed it; enter/review organization-controlled data and secondment vacancy options; submit/approve/return/reject as allowed.

Role	Permissions / Scope
Approving Authority	The configured executive approver for one or more routing units. May be a Approving Authority or Assistant/acting equivalent. Sees only requests routed through active authority assignments available to that user. Makes per-employee decisions and may return/reject with reason. One person may cover multiple units if explicitly configured. Temporary delegation is separate and audited.
Employee subject	No login and no direct interaction. Appears only as employee data within a request.

3.1 Role-Based Visibility

ID	Requirement	Source
FR-ACL-01	The backend shall enforce authorization independently of frontend route visibility.	S2 NFR-04
FR-ACL-02	Employee Affairs users shall see and act on requests they created/own, including requests returned to them.	S2 NFR-04
FR-ACL-03	Organization users shall see the Organization queue, unassigned work and requests claimed by themselves; claimed requests shall visibly show the claiming user to other Organization users.	S2 #4
FR-ACL-04	An Approving Authority shall access only requests whose active routing-unit authority assignment (or valid delegation) grants that user scope.	S2 BR-DEP-02
FR-ACL-05	Admin shall have system-wide account, audit and reporting scope but shall not be permitted to edit/delete audit events.	S2 #1,NFR-05
FR-ACL-06	Delegated Approving Authority access shall be scoped to a specific authority assignment/routing unit, explicitly created/disabled by Admin, and fully audited.	S2 BR-DEP-08
FR-ACL-07	Each active routing unit shall have exactly one active primary approving-authority assignment before pilot acceptance. The assigned person may be a Deputy, Assistant, acting Deputy or acting Assistant.	S6; engineering routing baseline
FR-ACL-08	The same approving authority may be assigned to more than one routing unit when approved by Admin/HR configuration; the system shall not enforce person-level uniqueness across units.	S6 evidence of combined responsibilities ; engineering correction

4. Business Rules

ID	Requirement	Source
BR-001	v1 contains exactly two business workflows: Secondment and Promotion.	S2 BR-PO-01
BR-002	Each request/form belongs to exactly one routing unit (النيابة / المساعد) and may contain multiple employees routed under that same unit.	S1 p4; S2 #32,#5
BR-003	There is no business maximum on the number of employees in one form; the UI and PDFs shall handle large forms through paging/page breaks.	S2 #5
BR-004	Employees included in the approved annual Excel snapshot are the eligible population for that cycle.	S2 #2
BR-005	Performance rating ممتاز or جيد جدا proceeds normally. Rating جيد shall show a warning to Employee Affairs and Organization but shall not automatically block progress.	S2 BR-ORG-05

ID	Requirement	Source
BR-006	A missing performance rating shall be displayed as unavailable and shall not be silently converted to a positive eligibility result. Human users retain the decision.	Engineering from S2 #1
BR-007	Secondment vacancy options are manually entered by Organization and are unlimited per employee.	S1 p3; S2 BR-ORG-02,03
BR-008	The Approving Authority decides secondment outcomes one employee at a time because reasons/notes may differ.	S2 BR-DEP-09
BR-009	For promotion, the Approving Authority decides “same position” versus “another position”; choosing another position requires manual entry of the target job title.	S2 BR-ORG-10,11
BR-010	Reject, return-for-correction and cancellation are distinct outcomes. Reject/return must include a reason.	S2 BR-EA-11, BR-DEP-04/05/06
BR-011	Any rejected/returned workflow returns to the originating Employee Affairs user, who decides whether to restart the request or cancel it.	S2 #13, #28, #40, #46
BR-012	Restart creates a new workflow iteration beginning at Employee Affairs while preserving every prior event and decision.	S2 #13, #28, #40
BR-013	Employee Affairs may recall a request at any non-final stage; recall starts a new iteration from the beginning and is audited.	S2 BR-EA-09
BR-014	After final Employee Affairs approval, the request is complete and immutable. It cannot be reopened through the normal application workflow.	S2 BR-EA-12, #7
BR-015	The final form is generated on demand from the frozen approved snapshot; regeneration shall not alter approved data.	S2 NFR-07, #7
BR-016	The audit log is a separate printable PDF and can cover one request or multiple requests in the same department, with period filtering.	S2 #6
BR-017	The 22 values supplied as النيابة / المساعد are routing units, not a guarantee of 22 distinct people. Each active unit must resolve to one current primary Approving Authority.	S2 #10 + S6
BR-018	An Approving Authority may hold a Approving Authority, Assistant or acting-equivalent job title. One person may cover multiple routing units if configured.	S6
BR-019	Request creation shall use controlled drop-downs for routing unit and current approving authority; only active approved authority assignments may be selected.	Stakeholder follow-up 15 Aug 2026
BR-020	The selected routing unit and approving authority identity/title shall be snapshotted with the request so later staffing changes do not rewrite historical approvals.	Engineering/ history requirement
BR-021	Printable-form subsections shall be selected from the approved job-category drop-down: نمطي ممتاز، نمطي ماهر. Candidates are grouped under the selected subsection.	S2 #8, #18; S4
BR-022	Secondment vacancy title and organizational dependency are manually entered by Organization; qualification compliance is selected from مستوفي / غير مستوفي. Promotion Other Position requires manual target-job entry by the Approving Authority.	S4; S2 BR-ORG/DEP answers

5. Functional Requirements

5.1 Authentication and Account Management

ID	Requirement	Source
FR-AUTH-01	v1 shall use application-managed local accounts. Active Directory/SSO is out of scope for v1.	S2 #8
FR-AUTH-02	The Admin Portal shall have a separate login route/UI from the operational Workflow Portal.	S2 #11,#69
FR-AUTH-03	Admin shall manually create operational user accounts with staff identifier, display name, username, role and any role-specific configuration. No supplied staff workbook or identifier list shall auto-create accounts.	S2 #1
FR-AUTH-04	Admin shall edit account metadata, deactivate/reactivate accounts and reset passwords. Physical deletion shall be represented as deactivation so historical actor references remain intact.	S2 #1; engineering
FR-AUTH-05	An admin password reset shall issue/set a temporary credential and require the user to change it at next login; the admin shall never be able to retrieve the current password.	Engineering security baseline
FR-AUTH-06	All account creation, edit, reset, activation/deactivation and delegation actions shall be written to the audit log.	S2 #1,#21
FR-AUTH-07	The application shall lock or rate-limit repeated failed login attempts and use generic authentication errors.	Engineering security baseline
FR-AUTH-08	A user session shall be invalidated when the account is deactivated or a password is reset.	Engineering security baseline
FR-AUTH-09	Role and department changes shall take effect on the next authorization check/session refresh and shall be audited.	Engineering security baseline
FR-AUTH-10	There shall be no public/self-service Admin registration route. The first privileged Admin shall be created only through a controlled backend/bootstrap command.	Engineering security decision
FR-AUTH-11	The bootstrap Admin shall use a temporary password, must_change_password=true, ADMIN role and Manage Admins privilege.	Engineering security decision
FR-AUTH-12	Only an active Admin with Manage Admins privilege may create/deactivate another Admin or change the Manage Admins permission.	Engineering security decision
FR-AUTH-13	The system shall reject any operation that would leave zero active Admins with Manage Admins privilege.	Engineering availability/security decision
FR-AUTH-14	Employee Affairs and Organization accounts shall be created manually by Admin from EGAS-supplied staff identifiers; those identifiers are deployment/configuration data and shall not be hard-coded into the SRS, architecture, source code or database seed scripts.	Stakeholder follow-up
FR-AUTH-15	Approving Authority accounts shall also be created manually by Admin. Admin shall manually enter the authority display name/job title and assign one or more routing units; job-title text shall not determine authorization automatically.	Stakeholder follow-up
FR-AUTH-16	An Approving Authority may be configured as Deputy, Assistant or acting equivalent. The role label/job title is descriptive; backend access is controlled only by explicit ApprovingAuthorityAssignment records and valid delegations.	Stakeholder follow-up; engineering safeguard

5.2 Annual Employee Data Import

ID	Requirement	Source
FR-IMP-01	The system shall support one controlled full-snapshot import for each annual dataset/cycle, nominally dated 1 July.	S2 #3,#4,#14
FR-IMP-02	The operational application shall not expose a general end-user Excel upload in v1; import is performed by an authorized technical operator/script.	S2 TR-06 context

ID	Requirement	Source
FR-IMP-03	Every import shall create an ImportBatch record containing year, source filename, source checksum, operator, timestamp, row counts and status.	Engineering
FR-IMP-04	Rows shall first be loaded into staging and validated before becoming active annual snapshots.	Engineering
FR-IMP-05	Personnel Number shall be required and unique within the annual snapshot.	S2 #16; S3
FR-IMP-06	The value "10" in performance rating and department shall be normalized to NULL.	Stakeholder #1,#9
FR-IMP-07	The importer shall preserve Arabic text in UTF-8 and convert Excel qualification-date values to dates where valid.	S3; Engineering
FR-IMP-08	Unmapped department values shall be reported and shall not be eligible for workflow routing until mapped to an approved department.	Engineering safeguard
FR-IMP-09	Existing completed/request snapshots shall remain unchanged after a later annual dataset is imported.	S2 NFR-06
FR-IMP-10	The application shall retain Employee identity separately from annual Employee Snapshot so the same person can have multiple yearly snapshots.	S2 #16; Engineering
FR-IMP-11	The annual eligible employee workbook shall be imported directly from .xlsx by the repository-controlled importer; conversion to CSV or use of an external database GUI is optional troubleshooting only, not the production import contract.	Engineering simplification
FR-IMP-12	The importer shall perform staging, validation, normalization, mapping and activation itself so the same rules are repeatable on the development PC, pilot laptop and future annual cycles.	Engineering

5.3 Employee Affairs Functions

ID	Requirement	Source
FR-EA-01	Employee Affairs shall create a new request by choosing Secondment or Promotion and the cycle year, then enter/search the first Personnel Number. The system shall derive the request routing unit from the employee annual snapshot as stated by the BRD.	S1 pp2-4
FR-EA-02	Employee Affairs shall enter one or more Personnel Numbers. For each valid number the system shall return the read-only annual employee data used by the form, including name, current job, level/subgroup, organizational/routing data, latest performance rating and original qualification/date fields available in the approved snapshot.	S1 p2
FR-EA-03	Employee details retrieved from the annual snapshot shall be read-only within the request and copied into an immutable request snapshot at submission.	S1 p4; S2 NFR-06
FR-EA-04	After the first employee establishes the request routing unit, the system shall reject adding another employee whose mapped routing unit differs; one form contains multiple employees from the same routing unit.	BR-002
FR-EA-05	Employees shall be grouped in the request/printout by job-title category such as مدير إدارة, رئيس نمطي ماهر and قسم, نمطي أول, نمطي ممتاز.	S2 #8,#18; S3
FR-EA-06	When performance rating is جيد, the system shall show an explicit warning and require the officer to acknowledge it before continuing.	S2 BR-ORG-05
FR-EA-07	Employee Affairs shall submit the request into the configured workflow and receive an in-app confirmation.	S1 workflow
FR-EA-08	The originating Employee Affairs officer shall be able to view current stage, current assignee/owner and complete status history for the request.	S2 NFR-04,#15
FR-EA-09	When the request is returned/rejected, it shall return to the same originating Employee Affairs user with the reason visible.	S2 NFR-04,#13
FR-EA-10	On a returned request, Employee Affairs shall choose Restart or Cancel. Restart creates a new iteration and may pre-populate the prior values for correction.	S2 #28
FR-EA-11	Employee Affairs shall be able to recall any non-final request; the recall reason shall be recorded and the workflow shall restart from the beginning.	S2 BR-EA-09

ID	Requirement	Source
FR-EA-12	In promotion, the intermediate Employee Affairs stage shall review Organization data and explicitly approve forwarding to the Approving Authority or return it for correction.	Stakeholder #3
FR-EA-13	At final approval, Employee Affairs shall approve the final results per candidate/request and freeze the approved snapshot.	S1 workflow; S2 BR-EA-12
FR-EA-14	The routing unit shall normally be determined automatically from Personnel Number/annual snapshot data rather than manually typed. If the source value is missing/unmapped, the request cannot proceed until the controlled mapping is resolved.	S2 #10; stakeholder follow-up
FR-EA-15	After routing unit resolution, the creation flow shall show a controlled Approving Authority drop-down filtered to active manual authority assignments for that routing unit. If exactly one active primary authority exists, it should be preselected but still displayed.	S6 + stakeholder follow-up
FR-EA-16	The legacy/final form requires a controlled subsection/job-category drop-down. The system shall support the approved categories; for secondment this grouping is selected during Organization preparation with the proposed job data. Promotion grouping shall be carried in the form preparation data without overriding the Approving Authority's final same/other-position decision.	S2 #18; S4

5.4 Organization Functions

ID	Requirement	Source
FR-ORG-01	Organization users shall have an unassigned work queue for requests at an Organization stage.	Stakeholder #4
FR-ORG-02	An Organization user shall claim an unassigned request using an atomic operation that prevents two users from taking the same request.	Stakeholder #4; Engineering concurrency
FR-ORG-03	After claim, all Organization users shall see the name/ID of the user who took the request.	Stakeholder #4
FR-ORG-04	For secondment, Organization shall add any number of manually entered candidate vacant positions per employee.	S1 p3; S2 BR-ORG-02
FR-ORG-05	Each secondment candidate position shall include position title and organizational affiliation/dependency as manually entered fields.	S1 pp3, final form S4
FR-ORG-06	Organization shall record qualification-compliance as مستوفي or غير مستوفي as a manual human judgment.	S4; S2 BR-ORG-05/06
FR-ORG-07	The application may provide a performance-based suggestion/warning, but Organization retains authority to proceed or reject/return.	S2 BR-ORG-05/06
FR-ORG-08	After the Approving Authority selects a secondment position, Organization shall review/confirm the selection and shall not silently change the Approving Authority decision.	S2 BR-ORG-08
FR-ORG-09	Organization may return/reject according to workflow rules; the action shall include a reason and return to the originating Employee Affairs user.	S2 BR-ORG-09
FR-ORG-10	For promotion, Organization shall review the request/form preparation data and forward it to the intermediate Employee Affairs review stage or return/reject with reason. The final Same Position / Other Position choice is not made by Organization; stakeholder clarification assigns that decision to the Approving Authority.	S2 routing + Stakeholder #3
FR-ORG-11	For secondment, vacancy Position Title and Organizational Dependency shall be free/manual text fields entered by Organization; Qualification Compliance shall be a controlled drop-down with مستوفي / غير مستوفي .	S4

ID	Requirement	Source
FR-ORG-12	For secondment, Organization shall select the form subsection/job category from the approved drop-down while entering proposed vacancies. Arbitrary subsection labels are not allowed; changes are audited.	S4 + data-integrity baseline

5.5 Approving Authority Functions

ID	Requirement	Source
FR-DEP-01	The backend shall route approval work using the request routing_unit_id and its selected ApprovingAuthorityAssignment, including any valid delegation.	S2 BR-DEP-01
FR-DEP-02	An Approving Authority shall see only requests covered by that user's active authority assignments/delegations.	S2 BR-DEP-02
FR-DEP-03	The Approving Authority shall make decisions per employee rather than only one batch decision for the entire form.	S2 BR-DEP-09
FR-DEP-04	For secondment, the Approving Authority shall select exactly one Organization-proposed position when approving that employee.	S1 p3
FR-DEP-05	The Approving Authority shall be able to reject an employee/request and shall be required to enter a reason.	S2 BR-DEP-04
FR-DEP-06	The Approving Authority shall be able to return for correction with a reason.	S2 BR-DEP-05/06
FR-DEP-07	For promotion, the Approving Authority shall choose Same Position or Other Position; Other Position requires entering the target job title.	S2 BR-ORG-10/11
FR-DEP-08	After a Approving Authority submits a decision, the decision is locked for that iteration. A correction requires return/restart rather than editing submitted history.	S2 BR-DEP-07 + restart rules
FR-DEP-09	Admin shall be able to configure a temporary delegated Approving Authority for a specific authority assignment/routing unit and later deactivate the delegation; delegate identity and actions shall be audited.	S2 BR-DEP-08
FR-DEP-10	The Approving Authority role shall be backed by an explicit manual Admin configuration linking an active application user to one or more routing units with authority kind (Deputy/Assistant/acting equivalent), descriptive job title and effective status. No authority assignment shall be inferred from spreadsheet job-title text.	S6 + engineering
FR-DEP-11	An authority user may cover multiple routing units when manually configured. Authorization shall be derived from ApprovingAuthorityAssignment records rather than a single department field or textual job title.	S6 + engineering correction

5.6 Notifications

ID	Requirement	Source
FR-NOT-01	Notifications in v1 shall be in-app only.	S2 #20
FR-NOT-02	A user shall receive a notification when a request becomes actionable for that user/role.	S1 p4,p6
FR-NOT-03	The originating Employee Affairs user shall be notified of reject, return, cancellation, recall consequences and final completion.	S2 NFR-04
FR-NOT-04	Organization users shall be notified/able to see new unassigned Organization work; when a request is claimed, the assignee shall be visible.	Stakeholder #4
FR-NOT-05	The responsible Approving Authority shall be notified when a request reaches the Approving Authority stage.	S1 notification requirement
FR-NOT-06	Notifications shall include request number, type, department, event/stage, actor when relevant, timestamp and a link to the request.	Engineering

ID	Requirement	Source
FR-NOT-07	Notifications shall have read/unread state and shall not substitute for the immutable audit log.	Engineering

6. Workflow Specifications

6.1 Secondment Workflow

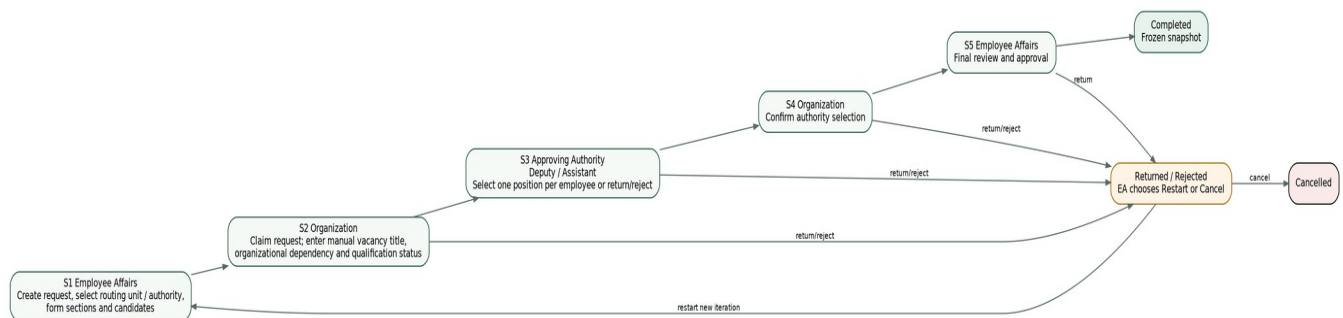


Figure note: the approval stage is performed by the configured Approving Authority (Deputy/Assistant), not by a hard-coded “Deputy per department” account.

Figure 2 - Secondment workflow including restart path.

Stage	Responsible Role	Required Action / Outcome
S1 - Draft	Employee Affairs	Choose request type/year; enter Personnel Numbers; system returns annual employee fields and derives/locks the routing unit; review warnings; select/confirm the filtered Approving Authority; submit.
S2 - Organization	Unassigned queue -> claim. Add unlimited candidate vacancies, organizational dependency and qualification-compliance values; submit or return/reject.	Unassigned queue -> claim. Review employee data; select subsection/job category from controlled list; add unlimited manual candidate vacancies, organizational dependency and qualification-compliance values; submit or return/reject.
S3 - Approving Authority	For each employee select one proposed position or reject/return with reason; submit decisions.	
S4 - Organization Confirmation	Review Approving Authority selections and approve forwarding; may return/reject but may not overwrite submitted Approving Authority selection.	
S5 - Employee Affairs Final	Review final result, approve final form or return before finalization.	
Completed	System	Freeze approved snapshot and expose final PDF generation; workflow cannot reopen normally.

6.2 Promotion Workflow

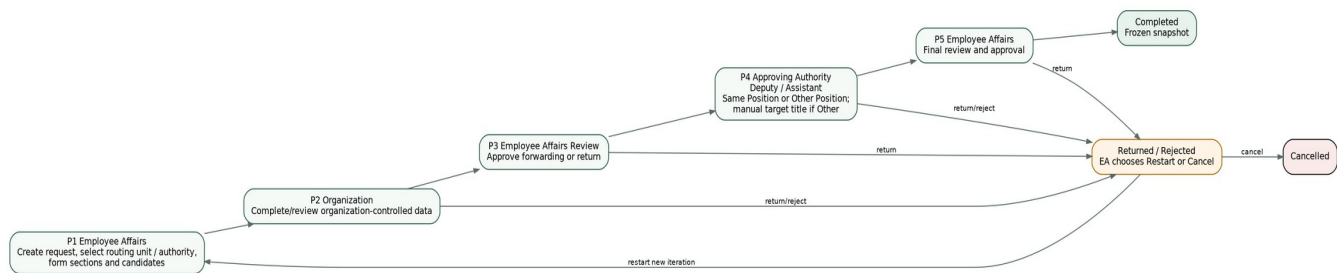


Figure note: the approval stage is performed by the configured Approving Authority (Deputy/Assistant).

Figure 3 - Promotion workflow including confirmed middle Employee Affairs review stage.

Stage	Responsible Role	Required Action / Outcome
P1 - Draft	Employee Affairs	Choose Promotion/year; enter Personnel Numbers; system returns annual employee fields and derives/locks routing unit; select/confirm filtered Approving Authority; submit.
P2 - Organization	Claim request and complete/review organization-controlled promotion data; submit or return/reject.	Claim request; review/prepare form grouping and organization-controlled information; forward to Employee Affairs review or return/reject. Do not decide Same/Other Position.
P3 - Employee Affairs Review	Review Organization data and explicitly approve forwarding to the Approving Authority or return for correction.	
P4 - Approving Authority	Per employee choose Same Position or Other Position; if Other, type target job title; approve/reject/return with reason.	
P5 - Employee Affairs Final	Review and give final approval or return before finalization.	
Completed	System	Freeze approved snapshot and expose final PDF generation.

6.3 Exception and Restart Semantics

- Return for correction and Reject create an actionable item for the originating Employee Affairs user and preserve the reason.
- Employee Affairs chooses Restart or Cancel after a return/rejection. Restart increments iteration_number and begins at the Employee Affairs start stage.
- Recall is initiated by Employee Affairs at any non-final stage and creates a new iteration from the beginning.
- Submitted stage decisions remain immutable in old iterations. Corrected values are captured in the new iteration.
- The request-level status is derived from the active iteration: Draft, In Progress, Returned, Cancelled, Completed. Detailed stage status is maintained separately.

7. Data and PostgreSQL Requirements

7.1 Source Workbook Mapping

Excel Column	Target Model	Rule
رقم الموظف	Employee.personnel_number	Required; unique employee business identifier and unique within annual snapshot.

Excel Column	Target Model	Rule
اسم الموظف	EmployeeAnnualSnapshot.employee_name	Preserve Arabic text exactly after whitespace normalization.
المجموعة الفرعية	EmployeeAnnualSnapshot.subgroup	Store source value; do not independently use it to exclude employees in v1.
النيابة / المساعد	EmployeeAnnualSnapshot.source_department + mapped department_id	Value "10" -> NULL. Non-null source value must map to an approved workflow department before use.
الوظيفة	EmployeeAnnualSnapshot.current_job_title	Store full Arabic text.
تقرير كفاية 2026	EmployeeAnnualSnapshot.performance_rating	ممتاز / جيد جدا / جيد; source "10" -> NULL.
المؤسسة التعليمية-المؤهل الاصلي	EmployeeAnnualSnapshot.qualification_source_1	Preserve source label/value; exact HR semantic name can be refined later without losing data.
الشهادة-المؤهل الاصلي	EmployeeAnnualSnapshot.qualification_source_2	Preserve source label/value.
تاريخ المؤهل الاصلي	EmployeeAnnualSnapshot.qualification_date	Nullable date.

7.2 Core Entities

Entity	Purpose / Key Fields
Employee	Stable identity: internal UUID + unique Personnel Number.
EmployeeAnnualSnapshot	Immutable yearly row: employee, year, name, subgroup, department mapping, current job, performance, qualification fields, source row.
RoutingUnit	Approved المساعدة / النيابة values used for routing. Stores Arabic name, active status and optional unit-kind metadata.
UserAccount	Local application account manually created by Admin: username, staff identifier, display name, optional descriptive job title, role, password hash, active state, must-change-password flag and Manage Admins permission where applicable.
AuthorityDelegation	Temporary audited delegation tied to a specific ApprovingAuthorityAssignment.
WorkflowRequest	Form header: type, cycle year, routing unit, selected approving-authority assignment + frozen authority snapshots, creator, status/current stage/current iteration, timestamps.
RequestCandidate	Employee included in a request, linked to annual snapshot and frozen candidate snapshot fields.
WorkflowIteration	Restart-safe workflow pass, iteration number and lifecycle state.
StageTask	Current/actionable stage task, claim/assignee, timestamps and state.
SecondmentPositionOption	Unlimited manual options per candidate, org dependency, qualification-compliance, selected flag.
PromotionDecision	Same/Other position decision and target title.
Notification	In-app recipient notification and read state.
AuditEvent	Append-only event with actor, action, request/stage, reason, metadata/diff, timestamp and hash-chain fields.
ImportBatch / ImportStagingRow	Annual eligible employee .xlsx import metadata plus raw staging/validation rows; no account or authority auto-import.

Entity	Purpose / Key Fields
PdfGenerationLog	Records generated report type, filter/request scope, template version, actor, timestamp and document hash.
RoutingUnit	The 22 approved النياية / المساعد routing values used by forms and workflow routing.
ApprovingAuthorityAssignment	Manual Admin configuration mapping a routing unit directly to an active Approving Authority user, authority kind and descriptive job title/effective status; the same user may cover multiple routing units.
AuthorityDelegation	Temporary audited delegation for an Approving Authority assignment without rewriting the primary assignment history.
RequestFormSection	Request subsection selected from the approved job-category reference; candidates link to sections for grouping/printing.

7.3 Key Data Constraints

ID	Requirement	Source
DR-001	Employee.personnel_number shall be globally unique in the application.	S2 #16
DR-002	EmployeeAnnualSnapshot shall be unique on (snapshot_year, personnel_number).	Engineering
DR-003	request/candidate/iteration/audit records shall reference valid routing/authority context; completed records shall preserve frozen snapshots rather than rely on later configuration.	BR-002
DR-004	Completed request/candidate/decision records shall not be updated by ordinary workflow operations.	S2 #7
DR-005	AuditEvent shall be append-only; no normal role including Admin shall have update/delete operations on audit events.	S2 NFR-05
DR-006	Stage claim shall be protected with a database transaction/compare-and-set rule so only one Organization user can claim an unassigned task.	Stakeholder #4
DR-007	Indexes shall support Personnel Number lookup, request status/stage, routing-unit/period filtering, assigned-user queues, request history and audit filtering.	Engineering
DR-008	All database text storage shall support Unicode/UTF-8 Arabic data.	S3
DR-009	Each active routing unit shall have at most one active primary ApprovingAuthorityAssignment; pilot preflight shall verify complete coverage.	Routing integrity
DR-010	An authority person/user may be primary for more than one routing unit; no uniqueness constraint shall prohibit this.	S6 combined responsibilities
DR-011	WorkflowRequest shall store the selected ApprovingAuthorityAssignment and frozen authority staff identifier/name/manual job-title/authority-kind snapshots so later account or assignment changes do not rewrite history.	Historical integrity
DR-012	RequestFormSection.job_category shall reference only نمطي رئيس قسم، نمطي مدير إدارة، أول، نمطي ممتاز، نمطي ماهر.	S2 #8; S4

8. Search, Reporting and PDF Requirements

8.1 Search and History

ID	Requirement	Source
FR-SRCH-01	Authorized users shall search requests by request number, type, cycle year, department, employee Personnel Number, employee name, current stage/status and date period.	S1 p6; S2 #15

ID	Requirement	Source
FR-SRCH-02	Search results shall respect role scope; backend authorization shall be applied before returning rows.	NFR-04
FR-SRCH-03	Employee Affairs shall see the complete lifecycle of owned requests, including prior iterations and return reasons.	S2 NFR-04,#15
FR-SRCH-04	Admin shall have system-wide search and audit filters.	S2 admin scope
FR-SRCH-05	History shall show current stage for in-progress requests and final outcome for completed/cancelled requests.	S2 #15

8.2 Management Dashboard (Proposed MVP)

Product-owner completion: The stakeholder requested that missing management dashboards be proposed by engineering. The following are proposed as simple operational reports rather than advanced BI.

- Pending requests by workflow and current stage.
- Unassigned Organization queue and currently claimed Organization workload.
- Requests created/completed/cancelled/returned/rejected by period and department.
- Average and median workflow cycle time by workflow and department.
- Aging list for requests that have remained in the same stage longer than a configurable threshold.
- Promotion vs secondment volume by month/quarter/year.
- Performance-warning counts (جيد or missing) by cycle, for process oversight only.
- Annual import status: active snapshot year, row counts, validation issues and import timestamp.

8.3 Final Form PDF

ID	Requirement	Source
FR-PDF-01	The system shall generate a redesigned digital Arabic PDF rather than requiring an exact pixel replica of the legacy paper form.	Stakeholder #6
FR-PDF-02	The final form shall preserve the official business information represented in S4 and group employees by job-title category.	S4; S2 #18
FR-PDF-03	Promotion PDF shall include request/department/cycle header, candidate name, current job, qualification fields, performance data, same/other-position decision, target position when applicable, notes and approval summary.	S4 + S2
FR-PDF-04	Secondment PDF shall include candidate name, current job, proposed/selected vacant positions, organizational dependency, qualification-compliance, notes, qualification fields, performance data and approval summary.	S4 + S2
FR-PDF-05	The final PDF shall contain a concise approval section listing involved parties/actors, user ID, role, decision and date/time; detailed technical history belongs in the separate Audit Log PDF.	S2 BR-EA-08 + stakeholder #6
FR-PDF-06	PDF generation shall be on demand. For completed requests the PDF shall always use the frozen approved snapshot.	S2 NFR-07,#7
FR-PDF-07	The PDF renderer shall correctly shape Arabic, use RTL layout and support multi-page tables without clipped rows.	UI requirement
FR-PDF-08	A field noted in the legacy promotion form as "تقرير آخر ترقية" shall be preserved as a configurable/manual field until its authoritative source/format is confirmed.	S4 open item

8.4 Audit Log PDF

ID	Requirement	Source
FR-AUDPDF-01	Audit log printing shall be separate from the final business form.	Stakeholder #6

ID	Requirement	Source
FR-AUDPDF-02	A user with permission shall print the complete audit history for one promotion/secondment request.	Stakeholder #6
FR-AUDPDF-03	Admin/authorized reporting users shall print an audit report covering multiple requests within the same department.	Stakeholder #6
FR-AUDPDF-04	Department audit filters shall support daily, weekly, monthly, quarterly, half-yearly and yearly periods.	Stakeholder #6
FR-AUDPDF-05	Each audit row shall identify request, employee/candidate when applicable, actor name, actor/user ID, role, action, from/to stage, outcome/reason and timestamp.	S2 #21
FR-AUDPDF-06	For incomplete requests, the report shall clearly identify the current in-progress stage; for completed requests, all completed stages shall appear.	S2 #15

9. Security Requirements

ID	Requirement	Source
SEC-001	Passwords shall never be stored in plaintext or with a general-purpose fast hash such as raw SHA-256. Use a salted adaptive password-hashing algorithm; Argon2id is the preferred baseline.	E4; correction to S2 #67
SEC-002	Authentication cookies/session identifiers shall be random, unguessable, HttpOnly, Secure when HTTPS is enabled, and protected with SameSite settings appropriate to the internal deployment.	Engineering
SEC-003	Server-side authorization shall enforce role, request ownership/assignment and department scope on every protected service/action.	S2 NFR-04; E2
SEC-004	Secrets such as database passwords and signing/session secrets shall be supplied through server secret/environment configuration and shall never be committed to Git.	Correction to S2 #68
SEC-005	The application shall use TLS/HTTPS on the internal network for production-like operation.	Corporate security baseline
SEC-006	Audit events shall be append-only and tamper-evident. A hash chain may use SHA-256 because this is integrity protection, not password storage.	S2 NFR-05; Engineering
SEC-007	Sensitive operational logs shall not contain plaintext passwords, session tokens or database secrets.	Engineering
SEC-008	All data-changing actions shall validate input lengths/enums/state transitions on the backend.	Engineering
SEC-009	The application shall protect against IDOR by deriving role/ownership scope from the authenticated user rather than trusting client-supplied user IDs.	Engineering
SEC-010	The application shall apply CSRF protection appropriate to its cookie/session design and shall use restrictive CORS if frontends and API use separate origins.	Engineering
SEC-011	Admin account-management actions and authentication events shall be security logged.	S2 #1; OWASP ASVS baseline
SEC-012	Production release shall include dependency/vulnerability review and source-control secret scanning.	Engineering

10. Non-Functional Requirements

10.1 Performance and Capacity

ID	Requirement	Source
NFR-PERF-01	On the EGAS LAN, employee lookup by Personnel Number should complete within 1 second at p95 under normal load.	S2 NFR-01 + engineering metric
NFR-PERF-02	Normal workflow read/write actions should complete within 1.5 seconds at p95, excluding PDF generation and large report exports.	S2 NFR-01 + engineering metric
NFR-PERF-03	Initial authenticated application navigation should feel near-instant after assets are cached; normal page transitions should avoid full page reloads.	S2 NFR-01
NFR-PERF-04	The design shall comfortably support the stated corporation scale of approximately 1,500 employees; pilot load testing shall use at least 100 concurrent authenticated sessions until IT provides a measured peak.	S2 BR-PO-05 + engineering baseline

ID	Requirement	Source
NFR-PERF-05	Large request and audit tables shall use server-side pagination/filtering rather than loading unbounded history into the browser.	Engineering

10.2 Availability, Reliability and Retention

ID	Requirement	Source
NFR-REL-01	Target service availability is 99% during the defined operating period, subject to local infrastructure and pilot constraints.	S2 NFR-02
NFR-REL-02	Database transactions shall ensure stage transitions, claims and audit writes are atomic.	Engineering
NFR-REL-03	Completed request snapshots and audit history shall remain readable after future annual dataset imports.	S2 NFR-06
NFR-REL-04	Pilot backup may be minimal; production backup, restore testing and disaster recovery shall be finalized with EGAS IT before production approval.	S2 TR-20
NFR-REL-05	PDF generation failure shall not modify workflow state; users shall receive a retryable error and the failure shall be logged.	Engineering

10.3 Browser and Accessibility

ID	Requirement	Source
NFR-UI-01	Support current company-approved versions of Chrome, Firefox and Edge.	S2 NFR-08
NFR-UI-02	Primary supported viewport is laptop/desktop; core functionality shall remain usable on common large-screen resolutions without horizontal page overflow.	S2 BR-PO-08, NFR-08
NFR-UI-03	The UI shall target WCAG 2.2 Level AA conformance.	S2 NFR-08; E5
NFR-UI-04	Arabic shall be the default interface language and layout direction. English is a future enhancement, but labels/messages should be isolated in translation resources.	S2 BR-PO-03

11. UI/UX and Accessibility

- Use Fiori-aligned visual patterns through UI5 Web Components while remaining a standalone React application.
- Use Arabic RTL navigation, tables and forms by default; support mixed Arabic/English IDs and numbers without broken ordering.
- Role-specific home screens: Employee Affairs “My Requests”; Organization “Unassigned / My Claimed”; Approving Authority “My Routing-Unit Decisions”; Admin “Accounts / Authority Mapping / Audit / Reports”.
- Prominent status chips for Draft, In Progress, Returned, Cancelled and Completed; always show current stage and current assignee where allowed.
- Warnings for performance rating جيد or missing shall be visually distinct from blocking validation errors.
- Keyboard navigation, visible focus, accessible labels, color contrast and semantic status text shall be tested against WCAG AA.
- Long Arabic names/job titles and multi-line organization text must wrap rather than overflow tables.
- Google Stitch is the design/prototyping source for all v1 login pages, dashboards and core role-specific screens. Approved Stitch outputs define visual hierarchy and interaction intent but do not override SRS business rules or backend authorization.
- Stitch shall use synthetic/sample content only. Real employee personal data, passwords, database credentials and secrets shall not be placed in Stitch prompts/projects.
- The Employee Affairs New Request wizard shall begin with request type/year and Personnel Number lookup. The routing unit shall be derived from the annual snapshot; the Approving Authority shall come from a filtered controlled drop-down

of active manual assignments. The secondment form subsection/job category is selected during Organization preparation; manual secondment fields and qualification-status drop-down shall match the supplied form semantics.

11.1 Suggested Screen Inventory

Portal / Role	Screens
Workflow - Employee Affairs	Login; My Requests; New Request wizard; Request detail/timeline; Returned Request correction/restart; Promotion intermediate review; Final approval; Search/history; PDF actions.
Workflow - Organization	Login; Unassigned queue; My Claimed; Request detail; secondment vacancy editor; qualification-compliance controls; post-Approving Authority confirmation; return/reject.
Workflow - Approving Authority	Login; routing-unit inbox; request/candidate detail; per-employee secondment selection; promotion same/other-position decision; notes/reason; submitted history. Authority scope comes from active assignment/delegation records and may include more than one routing unit.
Admin Portal	Admin login; Users; Create/Edit/Deactivate/Reset; Manage Admins; Routing Units; Authority Directory import; Approving Authority mapping; Delegation; Audit search/export; Management dashboard; Import batch status; system settings.

12. Deployment and Operations

- The v1 application is locally hosted on EGAS infrastructure and accessed from the internal network.
- Future access through internal network + VPN is an approved direction but is not required for pilot acceptance.
- The exact server OS, reverse proxy, container policy and production database host are controlled by EGAS IT and shall not be hard-coded into business logic.
- Configuration and secrets shall be external to source code. Separate environment configuration shall be used for development/test/production.
- Annual employee import shall be a controlled operational procedure implemented by the repository-owned XLSX importer, with source checksum, raw staging, validation report and explicit activation. pgAdmin/DBEaver may be used for inspection/troubleshooting but are not the authoritative import process.
- The complete runtime source shall be stored in a private GitHub repository. Secrets, real HR Excel files, database backups and generated real employee PDFs shall remain outside Git.
- The repository shall include AGENTS.md, README.md, PILOT_SETUP.md, .env.example, versioned SRS/Architecture PDFs, approved Stitch design assets/rules, Codex implementation prompt, migrations/import scripts and automated tests.
- The pilot laptop shall be reproducible from: (1) repository clone, (2) machine-local .env/secrets, and (3) PostgreSQL backup/restore or controlled imports. Application/API code shall not be intentionally omitted from the repository.

13. Testing Requirements

13.1 Critical Functional Tests

- Import annual snapshot and confirm "10" normalization to NULL plus uniqueness/department mapping validation.
- Employee Affairs creates multi-employee request for one department and cannot mix unmapped departments.
- Organization claim is atomic; a second user cannot claim the same task and sees the first claimant.
- **Secondment supports unlimited position options and Approving Authority selects per employee.**
- **Promotion follows Employee Affairs -> Organization -> Employee Affairs review -> Approving Authority -> Employee Affairs final.**
- جيد rating produces warning but user can proceed after acknowledgment.

- Reject/return with reason reaches originating Employee Affairs; restart creates iteration 2 and preserves iteration 1.
- Recall from each non-final stage restarts from beginning and is audited.
- Final approval freezes data; attempted normal edit/reopen is blocked.
- Final form PDF is Arabic/RTL, multi-page safe and generated from frozen data.
- Audit PDF works for one request and for department-period filters including daily through yearly.

13.2 Critical Security Tests

- **Approving Authority cannot access another routing unit by editing URLs/IDs.**
- Employee Affairs cannot access another officer's restricted request through direct API calls unless granted a broader admin role.
- Organization cannot edit a request claimed by another user.
- Admin cannot update/delete audit events through UI or API.
- Password hashes are Argon2id/adaptive hashes, not plaintext/raw SHA-256.
- Deactivated/reset account sessions stop working.
- Secrets are absent from repository and client bundles.
- State transitions outside the defined workflow are rejected by the backend.

14. Delivery Phases

Phase	Scope
1 - Foundation	Repo structure, CAP backend, PostgreSQL, local authentication/session, roles, 22 routing units, first-Admin bootstrap/Manage Admins, authority-assignment model, Admin Portal account management, audit framework.
2 - Data & Routing	Annual employee Excel staging/import; authority-directory staging/import; routing-unit and approving-authority mapping; reference drop-downs; employee identity + annual snapshots; employee lookup.
3 - Request Core	Workflow Portal shell, Employee Affairs request creation, request/candidate snapshots, status/timeline, in-app notifications.
4 - Secondment	Organization claim queue, unlimited manual vacancy options, qualification drop-down, Approving Authority selection, Organization confirmation, returns/restarts.
5 - Promotion	Organization stage, intermediate Employee Affairs review, Approving Authority same/other-position decision, manual target job where applicable, final approval.
6 - Documents & Reports	Final form PDF, audit PDF filters, search/history, management dashboard.
7 - Hardening & UAT	Security controls, performance/load tests, accessibility, browser matrix, backup/restore procedure, stakeholder UAT and deployment documentation.

15. Acceptance Criteria

- All four application roles can authenticate through local accounts and are limited to their defined backend scopes.
- **Admin can create/edit/deactivate/reset accounts and create a delegated Approving Authority account with all changes audited.**
- The supplied annual Excel structure can be imported into PostgreSQL with validation, Arabic preservation and yearly snapshots.
- Secondment and promotion follow the confirmed routes and all return/reject/recall/restart scenarios preserve history.
- Organization self-assignment is concurrency-safe and claimant identity is visible to other Organization users.

- **The responsible Approving Authority sees only work covered by active routing-unit assignments/delegations and makes decisions per employee.**
- Completed requests are immutable and regenerate the same approved business data in the final PDF.
- Final business form and separate audit-log PDF meet the defined print/filter requirements.
- Search, current-stage tracking and in-app notifications operate for all applicable roles.
- Security, accessibility, browser and performance tests in this SRS pass before pilot acceptance.

16. Open Items and Engineering Baselines

Item	Current Treatment / Needed Decision	Blocking?
Legacy "تقرير آخر ترقية" field	Keep a manual/configurable promotion-form field with the exact approved label until HR confirms authoritative source and data type.	No for workflow; yes before final form sign-off.
Annual dataset owner/operator	The system records operator/import metadata; EGAS IT/HR shall assign the operational owner before production.	No for development .
Department mapping discrepancies	Annual import blocks/unmaps rows whose source department is not mapped to the approved workflow department list. Mapping must be completed before those employees enter a workflow.	No for architecture; data setup required.
Session timeout	Engineering baseline: 30-minute idle / 8-hour absolute session, configurable and subject to EGAS cybersecurity policy.	No.
Production backup/DR	Pilot minimal backup accepted; production values to be defined by IT.	Production gate.
Server/containers	Local hosting confirmed; Windows/Linux, IIS/Nginx and container policy remain IT deployment choices.	No for application design.
22-unit authority mapping	Admin setup must manually create/confirm the current primary Approving Authority account, descriptive title/authority kind and routing-unit assignment for every active unit before pilot acceptance.	Data/setup gate

17. Traceability and References

17.1 High-Level Traceability

Source Requirement / Decision	SRS Coverage
BRD: two workflows, departmental routing	BR-001, Section 6
BRD: automatic employee data retrieval	FR-IMP/FR-EA via PostgreSQL annual snapshot
BRD: notifications between stages	FR-NOT-*
BRD: search/history	FR-SRCH-*
BRD: PDF and complete Audit Log	FR-PDF-*, FR-AUDPDF-*, SEC-006
Stakeholder: no SAP v1 / annual Excel	Scope 2.2, FR-IMP-*
Stakeholder: local accounts / admin	FR-AUTH-*
Stakeholder: confirmed workflow routes	Section 6
Stakeholder: rejection/return/restart semantics	BR-010..014, Section 6.3
Stakeholder: Organization claim queue	FR-ORG-01..03
Stakeholder: final form redesign + separate audit PDF	Section 8.3/8.4

Source Requirement / Decision	SRS Coverage
Stakeholder: manual operational accounts + Deputy/Assistant routing configuration	FR-AUTH-14..16, FR-EA-14..16, FR-DEP-10..11, Data Section 7
Printable form: job-category subsection dropdown + manual fields	BR-021..022, FR-EA-16, FR-ORG-11..12

Source and Engineering Reference Legend

Ref	Document / Standard	Use
S1	Business Requirement Document - Appraisal (6 pages)	Primary business source for workflow, roles, notifications, PDF and audit requirements.
S2	EGAS Missing Requirements Register Bilingual v0.3 - stakeholder answers	Confirmed stakeholder decisions recorded in the answer notes on pages 2-5.
S3	(1) البيانات الاساسية.xlsx	Annual Arabic HR snapshot supplied for PostgreSQL import; current workbook contains 484 employee rows.
S4	(1) نموذج.doc	Reference final promotion and secondment printable forms and required table fields.
S5	Mom's Cloud Kitchen SRS v2.1 Revised	Structure/style reference only; no food-ordering business requirements are carried into EGAS.
E1	SAP CAP - PostgreSQL guide	Engineering reference for @cap-js/postgres and CAP persistence.
E2	SAP CAP - Authentication / Authorization guides	Engineering reference for CAP user/role authorization boundaries.
E3	UI5 Web Components documentation	Engineering reference for Fiori-aligned React UI components, RTL and accessibility.
E4	OWASP Password Storage Cheat Sheet	Engineering reference for Argon2id / salted adaptive password hashing.
E5	W3C WCAG 2.2	Accessibility baseline; stakeholder requested Level AA.
S6	النواب والمساعدین.xlsx	Reference-only staff workbook. Because titles are inconsistent/mixed, v1 does not import it to create accounts or infer routing authority.
S7	Stakeholder follow-up - 15 Aug 2026	Confirmed manual operational account creation and explicit Approving Authority configuration; staff identifiers are entered operationally and are not embedded in specification/source seeds.
S8	Google Stitch design handoff decision	Approved UI design/prototyping source for login, dashboard and workflow screens; synthetic data only.
S9	Development handoff decision - GitHub + Codex	Codex receives SRS + Architecture + approved Stitch UI + implementation prompt; private repository contains complete runtime source and stable pilot commands.

Engineering links: <https://cap.cloud.sap/docs/guides/databases/postgres> ; <https://cap.cloud.sap/docs/guides/security/authorization> ; <https://ui5.github.io/webcomponents/> ; https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html ; <https://www.w3.org/TR/WCAG22/>

18. Implementation Handoff and Repository Contract

The implementation package supplied to Codex shall consist of the latest SRS PDF, latest Architecture PDF, approved Stitch screens/exports and DESIGN.md (or equivalent design rules), the versioned Codex implementation prompt, AGENTS.md repository instructions, and the PostgreSQL/CAP schema baseline. Business rules and authorization in the SRS take precedence over visual design output.

The private GitHub repository shall be complete and cloneable. Runtime frontend/backend/API source, database model/migrations, importers, PDF/audit code, tests and operational scripts belong in Git. Machine secrets and real HR operational data do not.

Repository Item

Required Content

AGENTS.md	Persistent Codex/developer guardrails, source precedence, security rules and “do not invent business rules” instructions.
README.md	Developer overview and normal setup/build/test entry points.
PILOT_SETUP.md	Windows PC/laptop stakeholder-demo runbook including PostgreSQL restore/import and local start procedure.
.env.example	Names of required configuration variables only; no real passwords/secrets.
docs/requirements	Latest SRS and Architecture PDFs.
design/stitch	Approved Stitch screens/exports and DESIGN.md/design tokens/rules.
services/cap-api	CAP backend, authorization, workflow, import, audit and PDF logic.
apps/workflow-web + apps/admin-web	Production React/TypeScript UI implementations derived from approved Stitch designs.
scripts	Setup, migrations, Admin bootstrap, annual employee XLSX import, pilot checks, backup/restore.
tests	Synthetic fixtures and automated functional/security tests.
Stable developer/pilot command interface (to be implemented by Codex/package scripts):	
Command	Purpose
npm install	Install repository dependencies.
npm run setup	Validate prerequisites/configuration and perform safe local initialization.
npm run db:migrate	Bring PostgreSQL schema to the repository version.
npm run admin:bootstrap	Create the first privileged Admin when no privileged Admin exists.
npm run data:import -- --file <xlsx> --year <YYYY>	Stage, validate and activate the annual eligible employee snapshot.
npm run pilot:check	Validate environment, schema, privileged Admin, active annual dataset, routing-unit coverage, authority assignments and ports.
npm run pilot	Start CAP API + Workflow Portal + Admin Portal for local stakeholder demonstration.
npm run db:backup -- --file <path>	Controlled PostgreSQL backup wrapper.
npm run db:restore -- --file <path>	Controlled restore wrapper with safety confirmation.
npm test / npm run lint / npm run build	Release quality gates.
Pilot portability: move code by cloning the private repository; recreate machine-local .env/secrets from .env.example; move demo state with a controlled PostgreSQL backup/restore or re-run controlled imports. API route/source code is part of the repository; only credentials/secrets are excluded.	

19. Security Hardening Baseline (v1.6)

This section extends Section 9 Security Requirements and all related deployment/testing requirements. It is written as an implementation-verifiable baseline for the internal EGAS HR workflow and the Codex handoff.

19.1 Security Principles and Trust Model

SEC-HARD-001 - Deny-by-default server authorization

Every non-public backend service/action shall authenticate the session and authorize the role, routing-unit scope, request ownership/assignment, active delegation and current workflow stage before reading or changing protected data. Hidden buttons or routes in React are UX only and never a security boundary.

SEC-HARD-002 - No direct browser-to-database access

React applications shall communicate only with the CAP backend. No PostgreSQL credentials, connection strings, service-role credentials or database keys shall be embedded in frontend code, public build-time variables, browser storage or Stitch/Codex prompts.

SEC-HARD-003 - Data minimization

The application shall store only fields required for the promotion/secondment workflow, audit, reporting and approved account management. Additional HR fields from broader workbooks shall not be imported merely because they exist.

SEC-HARD-004 - Defense in depth

Security shall combine backend authorization, least-privilege database access, validated state transitions, optional PostgreSQL RLS for safely expressible row scopes, audit logging, HTTPS, secure sessions, input/output controls and deployment hardening.

19.2 Secrets and Source-Control Security

SEC-HARD-005 - Secrets outside Git

Database passwords, session/signing secrets, encryption keys and future external-service credentials shall be supplied through machine-local or approved secret-management configuration. .env containing real values shall be ignored by Git; .env.example may contain names/placeholders only.

SEC-HARD-006 - Frontend values are not secrets

Any variable delivered to browser JavaScript shall be considered public. A frontend API base URL may be public; credentials and privileged tokens may not.

SEC-HARD-007 - Secret scanning before push and release

The repository shall run automated secret scanning locally and/or in CI. GitHub push protection/secret scanning should be enabled when available. The repository shall expose a stable command such as `npm run security:secrets` for repeatable checking.

SEC-HARD-008 - Leaked-secret response and Git purge

If a real secret is committed, the secret shall be treated as compromised: revoke/rotate it immediately, update runtime configuration, remove it from Git history using an approved history-rewrite procedure, force-update affected refs if necessary, rescan branches/tags and record the incident. Deleting the value in a later commit is not sufficient.

19.3 Password, Login and Session Security

SEC-HARD-009 - Password hashing, not encryption

Passwords shall never be reversibly encrypted and shall never use raw SHA-256. Store only salted adaptive password hashes; Argon2id is the preferred baseline. Password reset shall create a temporary credential or controlled reset flow and require change at first login.

SEC-HARD-010 - Secure session cookies

Authenticated browser sessions shall use an opaque random session identifier in an HttpOnly cookie. Secure shall be enabled for HTTPS environments. SameSite shall be Strict where compatible or Lax when required by the selected login flow. Session tokens shall never be stored in localStorage/sessionStorage.

SEC-HARD-011 - Session lifecycle

Sessions shall have configurable idle and absolute lifetimes. Engineering defaults are 30 minutes idle and 8 hours absolute pending EGAS IT approval. Session identifiers shall rotate after login, password change and privilege-sensitive account changes. Logout, password reset, account deactivation and relevant role changes shall revoke server-side sessions.

SEC-HARD-012 - Login rate limiting and logout

Login shall be rate-limited by account identifier and source IP. Engineering baseline: after 5 failed attempts within 10 minutes, temporarily lock the account for 15 minutes; values remain configurable by EGAS IT. Responses shall not reveal whether a username exists.

SEC-HARD-013 - Anti-automation/bot protection

Use progressive throttling, temporary logout and suspicious-attempt detection before introducing an interactive challenge. CAPTCHA or another challenge may be enabled conditionally if EGAS IT requires it, but the offline/local pilot shall not depend on an external bot service.

SEC-HARD-014 - CSRF protection

Cookie-authenticated state-changing requests shall use an appropriate CSRF defense such as same-site cookies plus a server-issued CSRF token/validated origin strategy. GET/HEAD endpoints shall not mutate workflow state.

19.4 Authorization, Record Access and Tamper Resistance

SEC-HARD-015 - Object-level authorization / IDOR prevention

Every request, candidate, audit report, PDF, notification and account-management object shall be re-authorized on the server using the authenticated identity and current scope. Client-supplied user IDs, role names, routing units, request owners or authority identifiers shall never be trusted as proof of access.

SEC-HARD-016 - Field allow-listing / mass-assignment prevention

Write endpoints shall accept explicit DTOs/allow-lists only. Protected fields such as actor, created_by, workflow status, current stage, employee name/job, annual snapshot values, authority assignment and timestamps shall be derived by the server rather than accepted from arbitrary client payloads.

SEC-HARD-017 - Record concurrency control

Mutable workflow records shall use transactional conditional updates, row locks where required and/or optimistic version checks. Organization Take Request must remain atomic. Conflicting stale edits shall return a safe conflict response instead of silently overwriting another user.

SEC-HARD-018 - PostgreSQL Row Level Security

RLS shall be implemented as defense-in-depth on sensitive tables whose row scope can be safely expressed after the CAP backend establishes transaction-scoped user/role context. The application DB role shall not be a superuser, table owner or possess BYPASSRLS. RLS policies shall be covered by automated tests. Backend authorization remains mandatory even when RLS is active.

19.5 Query, Input and Output Security

SEC-HARD-019 - Parameterized database access

CAP/CDS/ORM parameter binding shall be used for data access. Any handwritten SQL shall use bound parameters; concatenating untrusted input into SQL text is prohibited.

SEC-HARD-020 - Validate every external input

Backend validation shall cover body fields, query parameters, path identifiers, filters, enum values, dates, pagination, notes, job titles, organization text, Excel workbook values, filenames and Admin configuration. Reject unexpected fields and values outside defined length/range/format limits.

SEC-HARD-021 - Output encoding and XSS prevention

User-controlled notes, reasons, job titles, display names and organizational text shall be rendered through safe React/UI5 text binding/contextual encoding. Unsafe raw HTML rendering of user data is prohibited. If HTML sanitization is ever required, it shall use an approved sanitizer and narrowly defined allow-list.

SEC-HARD-022 - Minimal API responses

API responses shall use explicit response DTOs/projections and return only fields required by the caller. Database entities shall not be serialized blindly. Password hashes, internal session data, unnecessary HR fields and internal authorization metadata shall never be returned to browsers.

SEC-HARD-023 - Request and query resource limits

Set safe limits for JSON/body size, query-string length, page size, date/report range, search length and computationally expensive operations. Unbounded list endpoints are prohibited.

SEC-HARD-024 - Safe error handling

Client errors shall use generic structured messages and correlation IDs without stack traces, SQL text, file-system paths, secret values or internal implementation details. Detailed diagnostics remain in protected server logs.

19.6 Controlled XLSX/File Ingestion

SEC-HARD-025 - Restricted file types

The annual import shall accept only the approved .xlsx workflow workbook format. Reject executable content, .xlsm/macro-enabled files and unrelated attachments unless a later requirement explicitly authorizes them.

SEC-HARD-026 - File verification and size limits

Validate extension, file signature/container structure, maximum file size, expected worksheet/header structure, row limits and data types before activation. Do not rely solely on browser MIME or filename.

SEC-HARD-027 - Controlled storage and filenames

Imported files, if temporarily retained, shall use server-controlled filenames/paths outside the public web root with restricted permissions and lifecycle cleanup. Original client paths/filenames shall not determine server storage locations.

SEC-HARD-028 - Staging before activation

No spreadsheet row becomes authoritative HR data directly. Store raw staging rows, validate/normalize according to approved rules, show an import summary, and activate a full annual snapshot only after validation succeeds.

19.7 Encryption and Transport Protection

SEC-HARD-029 - HTTPS/TLS

Production-like internal operation shall force HTTPS. HTTP may be used only for isolated localhost development. The reverse proxy shall redirect/reject plaintext production traffic and use HSTS after HTTPS is correctly deployed.

SEC-HARD-030 - Private database connectivity

PostgreSQL shall listen only on approved/private interfaces and be protected by host/network controls. The application uses a least-privilege DB login; operational users never connect directly to PostgreSQL for normal workflow use.

SEC-HARD-031 - Encryption at rest and backups

Production database volumes and backup media/files shall use approved platform/storage encryption where available. Backups shall be access-controlled like the live database and shall not be committed to Git. Separate encryption keys/secrets from encrypted data where platform capability permits.

SEC-HARD-032 - Application-level field encryption only when justified

If EGAS later requires storage of fields whose confidentiality warrants application-level encryption, use an approved authenticated encryption scheme and managed keys. Do not introduce reversible encryption for passwords.

19.8 Browser and HTTP Security Headers

SEC-HARD-033 - Content Security Policy

Serve a restrictive CSP compatible with React/UI5, disallowing unsafe inline/eval behavior unless a documented technical exception is required. Prefer self-hosted/internal resources for the pilot.

SEC-HARD-034 - Baseline headers

Production responses shall include appropriate X-Content-Type-Options: nosniff, frame protection via CSP frame-ancestors (and/or compatible X-Frame-Options), Referrer-Policy, Permissions-Policy and HSTS when HTTPS is active.

SEC-HARD-035 - Restrictive CORS

If the Admin Portal, Workflow Portal and API use different origins, allow only explicitly configured approved origins/methods/headers and credential behavior. Wildcard CORS with credentials is prohibited.

19.9 Logging, Audit and Security Monitoring

SEC-HARD-036 - Security event logging

Security logs shall cover successful/failed login, logout, password reset/change, session revocation, Admin creation/deactivation, Manage Admins changes, authority mapping/delegation changes, denied authorization attempts, annual import activation/failure and security-sensitive configuration changes.

SEC-HARD-037 - Log minimization and masking

Never log plaintext passwords, session tokens, CSRF tokens, database credentials, encryption keys or complete sensitive request bodies. Mask/truncate identifiers where full values are not operationally necessary and use correlation IDs for troubleshooting.

SEC-HARD-038 - Audit immutability

Business audit_event records remain append-only/tamper-evident. The application database role shall not receive normal UPDATE/DELETE permission on audit_event. Audit and security logging serve different purposes but may share correlation/request identifiers.

19.10 Dependency, Build and Repository Security

SEC-HARD-039 - Lockfile and reproducible install

Commit the package lockfile and use reproducible dependency installation in CI/pilot setup. Do not silently install arbitrary latest versions during deployment.

SEC-HARD-040 - Dependency and code scanning

Before pilot release and production deployment, run dependency vulnerability scanning, secret scanning and appropriate static/code-quality checks. High/critical findings affecting reachable runtime code shall be resolved or explicitly risk-accepted before release.

SEC-HARD-041 - No production debug exposure

Production/pilot mode shall not expose development stack traces, debug endpoints, unrestricted database consoles, hot-reload servers or unauthenticated API explorers. Public source maps shall be disabled unless protected/required for internal diagnostics.

SEC-HARD-042 - Stable security commands

The repository shall provide repeatable scripts such as npm run security:secrets, npm run security:scan and npm run security:check, and pilot:check shall include the release-critical subset.

19.11 Security Verification and Release Gate

SEC-HARD-043 - Automated authorization matrix

Tests shall prove that each role cannot access another role/unit/request outside its permitted scope, including direct URL/API attempts and modified object IDs.

SEC-HARD-044 - Security abuse tests

Test login rate limiting/lockout, session invalidation/rotation, CSRF defenses, SQL-injection resistance, mass assignment, XSS/output encoding, oversized inputs, malicious/invalid XLSX, CORS, security headers, HTTPS behavior, RLS policies where enabled, safe errors and dependency/secret scans.

SEC-HARD-045 - OWASP ASVS target

Use OWASP ASVS 5.0 Level 2 as the engineering verification target for the production-intended internal HR application, with documented exceptions where an item is not applicable to the selected architecture.

SEC-HARD-046 - Production security review

Before production approval with real operational data, EGAS IT/Cybersecurity shall review deployment configuration, TLS, secrets, database permissions/RLS, backup security and vulnerability findings. A penetration/security assessment should be performed according to corporate policy.

19.12 Explicitly Non-Applicable Checklist Item

SEC-HARD-047 - No public database key

The “use a public DB key” pattern is not applicable. This system uses a backend-mediated PostgreSQL architecture. The browser receives no database credential. If the architecture later changes to a BaaS platform, that security model must be reviewed separately rather than copied into the current system.

EGAS

System Architecture - Promotion & Secondment Workflow Website

Version 1.6 Draft - Security Hardening Update

Document Version	1.6 Draft
Date	15 August 2026
Update Type	Security hardening and secure implementation baseline
Applies To	All v1 functional, API, database, repository, pilot and deployment behavior
Precedence	This v1.6 update supersedes any weaker or conflicting security wording in the embedded v1.5 body.

Authoritative amendment rule

The original v1.5 body is retained for traceability. The security section appended after that body is part of this v1.6 document and is authoritative for Codex implementation, testing, repository policy and pilot/production deployment. Where the older body is silent, the appended security baseline applies. Where a conflict exists, the stricter v1.6 security requirement applies.

Important architecture clarification

The browser shall never receive a PostgreSQL username, password, connection string, service-role credential or so-called public database key. All database access remains backend-mediated. PostgreSQL Row Level Security (RLS) is defense-in-depth and does not replace server-side authorization.

EGAS

System Architecture Specification

Promotion & Secondment Workflow Website

Document Version	1.5 Draft
Status	Updated baseline: manual account/authority configuration, BRD role I/O reconciliation, simplified direct XLSX annual import
Primary Language	English specification; product UI defaults to Arabic (RTL)
Prepared For	Egyptian Natural Gas Holding Company (EGAS)
Date	15 August 2026

Source baseline: original BRD + confirmed stakeholder interview answers + annual eligible HR dataset + final printable forms + approved design/handoff decisions. The النواب والمساعدین workbook is reference-only; authorization is never inferred from its job-title text.

Revision Control

Version	Date	Status	Description
1.0	14 Aug 2026	Draft baseline	Architecture derived from confirmed SRS decisions and selected React + CAP + PostgreSQL stack.
1.1	15 Aug 2026	Draft update	Added secure first-Admin bootstrap, Manage Admins permission and protected Admin-to-Admin management.
1.2	15 Aug 2026	Draft update	Integrated Google Stitch as design-time UI source and portable local pilot pattern.
1.3	15 Aug 2026	Draft update	Added private GitHub/Codex handoff contract, AGENTS.md and stable pilot command interface.
1.4	15 Aug 2026	Draft update	Added النواب والمساعدین authority-directory source; replaced one-distinct-Approving Authority-per-unit assumption with configurable Approving Authority/Assistant authority assignments; added routing/form drop-down architecture and revised PostgreSQL model.
1.5	15 Aug 2026	Draft update	Removed authority-directory import dependency; made operational accounts/authority routing manual Admin configuration; added direct XLSX annual-import contract and BRD role input/output reconciliation.

Document Map

1. Executive Summary
2. Architecture Drivers and Decisions
3. System Context
4. Logical Architecture
5. Frontend Architecture
6. Backend/CAP Architecture

6.4 BRD Role Input / Output Contract

Employee Affairs -> input: request type/year and Personnel Number(s). Backend -> return: the current annual employee snapshot fields required by the form and the mapped routing unit. The first employee establishes/locks the request routing unit; later employees must map to the same unit. Employee Affairs then confirms the filtered active Approving Authority and submits.

Organization -> input (Secondment): claim the request; choose the controlled form subsection/job category; manually enter one or more proposed position titles, organizational dependencies and qualification-compliance values per candidate. Backend -> return: persisted options, warnings, audit events and the next workflow task.

Approving Authority -> input (Secondment): select exactly one Organization-proposed option per employee or reject/return with reason. Approving Authority -> input (Promotion): choose Same Position or Other Position; when Other Position, manually type the target job title. Backend -> return: frozen decisions, audit event, notification and next task.

Employee Affairs final -> input: final approval (or permitted return before finalization). Backend -> return: immutable completed request snapshot plus on-demand final-form and audit-log PDFs.

7. Workflow Engine Design
8. PostgreSQL Data Architecture

8.4 Manual Account and Authority Configuration

Only the first privileged Admin is created by bootstrap. All later Admin, Employee Affairs, Organization and Approving Authority accounts are created manually in the Admin Portal using EGAS-supplied staff identifiers. These identifiers are operational configuration and are not seeded into source-controlled documents or migrations.

Approving Authority job titles are entered manually because spreadsheet/job-title wording is not consistent enough to drive authorization. Admin explicitly maps an authority account to one or more RoutingUnit rows. The backend authorizes from these assignment records, not from display text.

The **النواب والمساعدین** workbook may be used by humans as reference during setup, but the v1 runtime does not require it and does not auto-import it to create accounts.

9. Annual Excel Import Architecture

9.3 Import Tooling Decision

Preferred operational path: `npm run data:import -- --file <xlsx> --year <YYYY>`. The script is part of the repository and reads .xlsx directly, then stages, validates, normalizes and activates rows. This keeps annual import repeatable and auditable without requiring the operator to manually recreate column mappings in a database GUI.

For development troubleshooting only, a database GUI may inspect tables or perform disposable test imports. It must not bypass the production staging/validation/activation rules.

- 10. Authentication and Security
- 11. Audit, Notifications and PDF
- 12. API/Service Boundaries
- 13. Deployment Architecture
- 14. Performance and Reliability
- 15. Future Integration Paths
- 16. Implementation Structure
- 17. Architecture Decision Records
- 18. Risks and Open Items
- 19. References
- 20. Repository, Stitch and Pilot Handoff

1. Executive Summary

The recommended v1 solution is a modular monolith: two React/TypeScript single-page applications (Workflow Portal and Admin Portal), a shared SAP Cloud Application Programming Model (CAP) Node.js/TypeScript backend, and PostgreSQL persistence. The system is deployed on EGAS internal infrastructure, uses local application authentication in v1, and imports a full HR Excel snapshot once per year. A second controlled staff-reference source, **النواب والمساعدین.xlsx**, is staged for routing-authority configuration. The 22 workflow routing units do not imply 22 distinct people: each unit resolves to one active primary Approving Authority, who may hold a Deputy, Assistant or acting-equivalent title, and the same person may cover multiple units when configured.

Why this architecture: The organization has a small number of tightly coupled workflow domains, approximately 1,500 corporate employees, no v1 SAP integration and one internal deployment boundary. A modular monolith minimizes operational complexity while keeping modules/interfaces clean enough for later SSO, SAP integration or separate services.

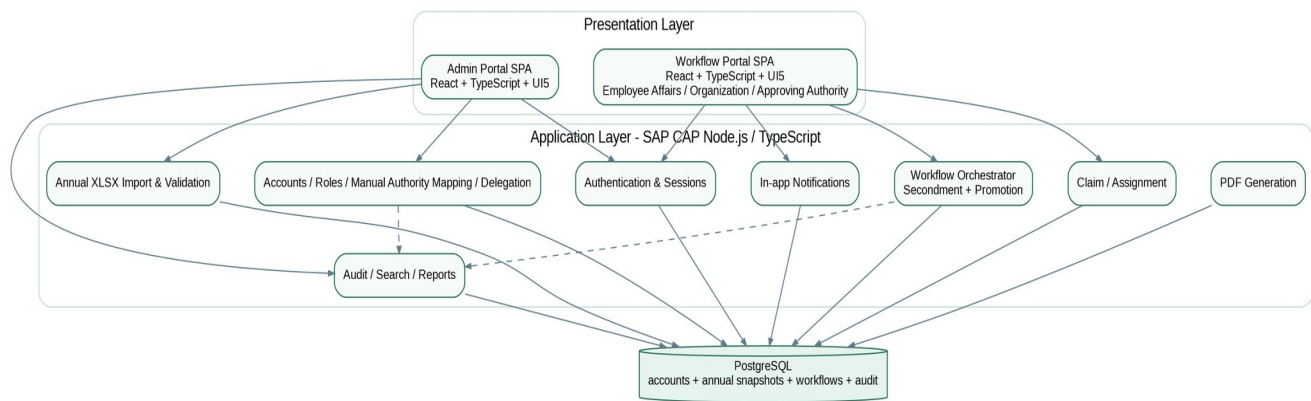


Figure 1 - recommended logical architecture.

2. Architecture Drivers and Decisions

Driver / Constraint	Architectural Response
Arabic-first internal workflow	React + UI5 Web Components, RTL layout, Noto Arabic fonts and server-generated Arabic PDF templates.
No live SAP in v1	Annual import boundary isolates HR source; workflow depends only on PostgreSQL snapshots.
Multiple roles / sensitive HR data	Backend-enforced RBAC + ownership + department scope; two frontend shells but one authorization model.
Multiple Organization users	Explicit unassigned queue and atomic claim transaction.
Restartable workflows	Request -> Iteration -> StageTask model; old iterations immutable.
Long-term audit	Append-only AuditEvent table with actor snapshots and tamper-evident hash chain.
Final records stable after yearly data changes	Requests reference immutable EmployeeAnnualSnapshot plus request-level frozen fields.
Local deployment now, VPN later	Internal HTTPS reverse proxy; no public-cloud dependency; VPN adds network path without changing application services.
Future AD/SAP possible	AuthenticationProvider and EmployeeDataProvider boundaries avoid coupling business logic to local auth/Excel.
Mixed Deputy/Assistant approval structure	Represent 22 routing units separately from people. Use AuthoritySourcePerson + ApprovingAuthorityAssignment with effective dates; do not encode a one-person-per-unit global uniqueness rule.
Printable form drop-down/manual fields	Reference tables for five form-section job categories and qualification status; manual text fields remain manual in domain models.
Stitch/Codex/GitHub handoff	Stitch is design-time only; private repository contains complete runtime source, requirements, approved design assets, AGENTS.md and reproducible pilot scripts.

2.1 Selected Technology Baseline

Layer	Selection	Notes
Workflow Frontend	React + TypeScript + UI5 Web Components	One SPA with role-specific Employee Affairs, Organization and Approving Authority dashboards; implementation follows approved Stitch designs.
Admin Frontend	React + TypeScript + UI5 Web Components	Separate route/deployment bundle and separate login UI; shares backend.
Backend	SAP CAP for Node.js + TypeScript	Modular services, CDS domain model, actions, authorization integration.

Layer	Selection	Notes
Database	PostgreSQL via @cap-js/postgres	CAP officially supports PostgreSQL through the @cap-js/postgres adapter.
Authentication	Custom local account/session provider for v1	Maps authenticated account to CAP user/roles; replaceable with AD/SSO later.
PDF	HTML/CSS + controlled headless Chromium renderer	Strong Arabic/RTL layout and reliable A4 landscape table printing.
Deployment	Internal reverse proxy/web server + Node.js application service + PostgreSQL	Exact OS/container choice remains EGAS IT policy.
UI Design / Prototype	Google Stitch	Design-time generation/iteration of Arabic RTL login, dashboard and workflow screens using synthetic data only; no runtime dependency.
Source Control / Agent Handoff	Private GitHub + AGENTS.md	Complete cloneable monorepo, versioned requirements/design assets and repository instructions for Codex.

3. System Context

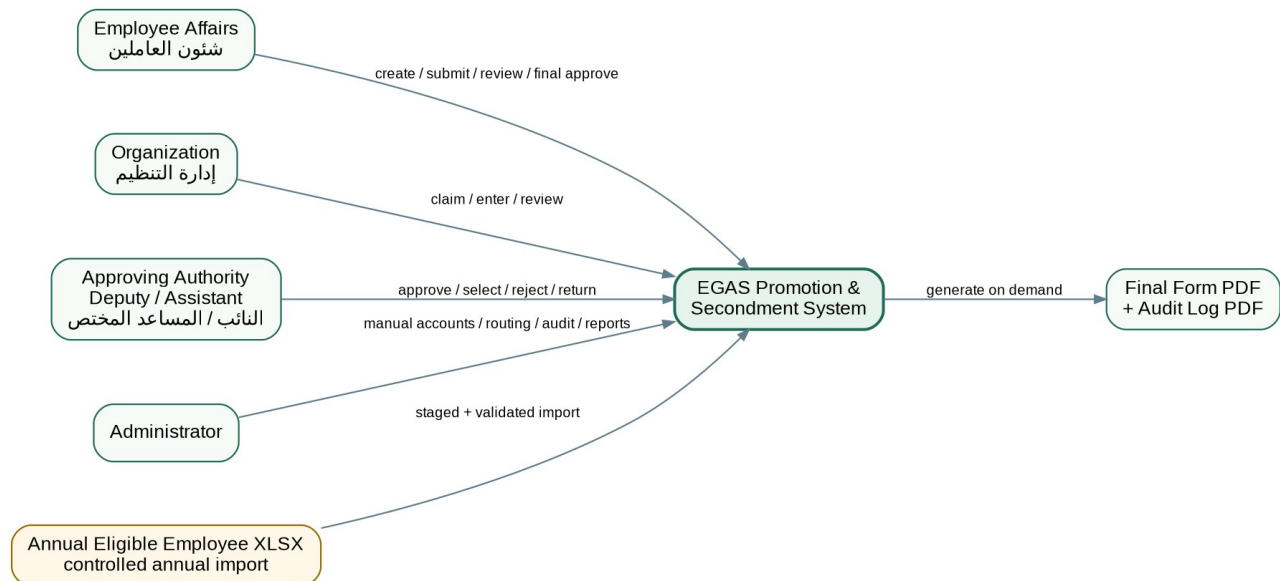


Figure note: v1.5 uses Approving Authority (Deputy/Assistant). Authority accounts, descriptive job titles and routing-unit mappings are configured manually by Admin; no spreadsheet title parsing is part of authorization.

Figure 2 - actors, annual data source and document outputs.

3.1 Trust Boundaries

- Browser boundary: all role decisions arriving from a client are untrusted until authenticated, authorized and validated by the backend.
- Import boundary: Excel files are untrusted input until staged and validated; rows are not activated directly.
- Database boundary: PostgreSQL is the source of truth for application accounts, annual snapshots, workflow state and audit events.
- PDF boundary: generated documents are derived outputs and never update workflow state.
- Future SSO/SAP boundaries are adapter interfaces only in v1; no network calls to SAP or AD are required.

4. Logical Architecture

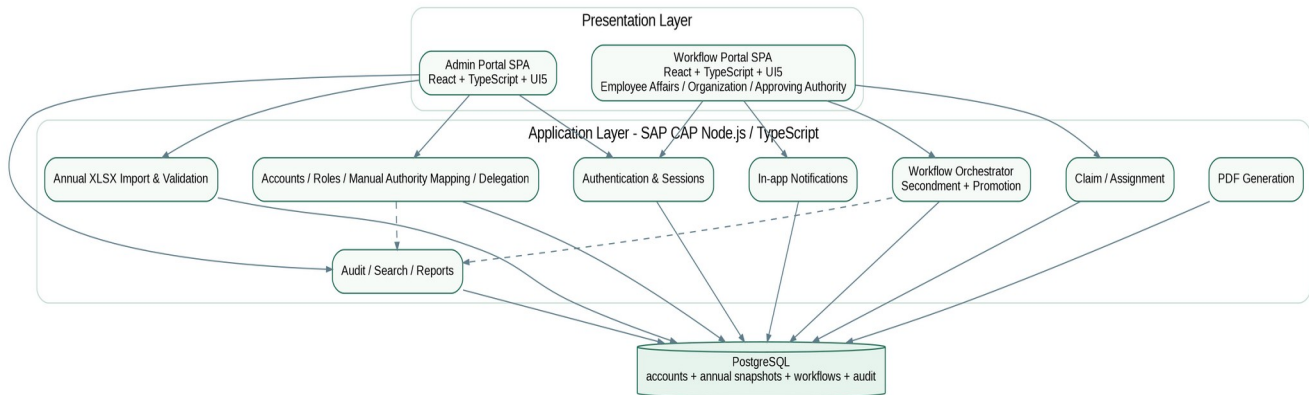


Figure 3 - logical modules and persistence.

4.1 Module Responsibilities

Module	Responsibilities
Auth & Session	Login/logout, password verification, session creation/revocation, must-change-password, failed-attempt controls, CAP user context.
Account & Delegation	First-Admin bootstrap; manual Admin CRUD/deactivation/password reset for all later Admin, Employee Affairs, Organization and Approving Authority accounts; Manage Admins permission; manual routing-unit authority mappings; temporary delegation.
Data Import & Reference	Annual eligible employee .xlsx staging/validation/activation; routing-unit mapping; job-category and qualification-status references. No operational account or authority-directory auto-import.
Employee Data	Personnel Number lookup, current active annual snapshot, historical snapshot access.
Workflow Orchestrator	State machine, valid transitions, iterations, finalization/freeze, return/restart/recall/cancel semantics.
Secondment	Manual position options, manual organizational dependency, qualification-status drop-down, Approving Authority selection, Organization confirmation.
Promotion	Organization review/preparation, intermediate Employee Affairs review, Approving Authority same/other-position decision and manual target job title when Other Position is selected.
Assignment	Unassigned Organization tasks, atomic claim/release/recovery rules.
Notifications	Recipient calculation, unread/read state, links into role-specific request screens.
Audit & Reporting	Append-only event creation, search, management KPIs and audit PDF data sets.
Document Generation	Final form HTML models, approval summaries, audit-report templates and PDF hashes.
Authority Routing	22 RoutingUnit records; manual ApprovingAuthorityAssignment to active user accounts; effective-date/current-primary resolution; request authority snapshots; multi-unit authority support; temporary delegation.
Form Structure Reference	RequestFormSection grouping using five approved job-category values; controlled drop-downs and PDF grouping.

5. Frontend Architecture

5.1 Application Split

Decision: Use two frontend applications, not four: (1) a Workflow Portal that renders role-specific routes/components for Employee Affairs, Organization and Approving Authority; and (2) a separate Admin Portal. This satisfies separate role UIs without multiplying deployment/build complexity.

Application	Primary Routes
Workflow Portal	/login, /home, /requests, /requests/new, /requests/:id, /organization/queue, /authority/inbox, /notifications, /history
Admin Portal	/admin/login, /admin/users, /admin/routing-units, /admin/authority-mappings, /admin/delegations, /admin/imports, /admin/audit, /admin/reports

5.2 Frontend State and Data Rules

- Server state is fetched through typed service clients; the browser never owns authoritative workflow status or permissions.
- Role routes are hidden/disabled in UX, but this is not a security boundary; backend CAP services enforce access.
- Request edit forms use optimistic client UX only for local unsaved values. Submissions are transactional backend actions.
- Arabic translation resources are separated from components so a future English pack can be added without rewriting screens.
- All status, reason and validation messages are represented as translation keys rather than hard-coded English strings.

5.3 UI Component Strategy

- UI5 ShellBar/Page/Toolbar/Table/Dialog/MessageStrip/Button/Select/Input/TextArea components for Fiori-aligned behavior.
- Virtualization or server-side pagination for large history/audit tables.
- Reusable RequestStatus, StageTimeline, CandidateCard, PerformanceWarning and ApprovalSummary components.
- RTL-safe responsive grid and compact density for large desktop data-entry screens.
- Approved Google Stitch screens define visual hierarchy, page composition, RTL interaction intent and shared design tokens. Stitch-generated code may be used as a scaffold but must be adapted to React + TypeScript + UI5 and must not create a runtime dependency on Stitch.
- Store approved Stitch exports/screens and DESIGN.md (or equivalent) under version control. Use synthetic data only in design assets.

6. Backend/CAP Architecture

6.1 CAP Service Boundaries

Service	Consumers	Scope
WorkflowService	Workflow Portal	Requests, candidates, stage actions, secondment/promotion actions, notifications, history.
AdminService	Admin Portal	Manual users/accounts, Manage Admins, routing units, manual Approving Authority mappings/job titles, delegations, annual employee import batches, audit/report administration.
ReportingService	Admin / authorized roles	KPIs, audit search, final form/audit PDF generation endpoints.
Auth HTTP endpoints	Both portals	Login, logout, session introspection, password change.
HealthService	Infrastructure	Liveness/readiness and database connectivity checks; no sensitive data.
ReferenceService	Workflow + Admin Portals	Routing units, active manual authority assignments, form-section job categories and qualification-status values; read-only reference data for workflow screens.

6.2 CAP Authorization

Authenticated local accounts are mapped into the CAP user abstraction. Service/entity/action restrictions use role checks for coarse authorization and custom handlers for ownership, department and assignment predicates. CAP's authorization model supports resource restrictions; the application still implements domain-specific checks for "own request", "own department" and "claimed by me".

6.3 Transaction Pattern

- Every workflow transition runs inside one database transaction: validate current state -> validate actor scope -> update iteration/task/request -> write audit event -> create notifications -> commit.
- If any step fails, the transition is rolled back and no partial audit/state mismatch is committed.
- Final approval performs an additional freeze operation that materializes final decision snapshots before setting Completed.

7. Workflow Engine Design

7.1 State Representation

Level	Example Fields	Purpose
WorkflowRequest	type, routing_unit_id, approving_authority_assignment_id, frozen authority snapshots, status, current_stage, current_iteration_no	Stable form identity, selected routing/authority context and current summary.
WorkflowIteration	iteration_no, status, started_at, ended_at, restart_reason	Preserves each complete/partial pass through the workflow.
StageTask	stage_code, assignee/claimant, status, opened_at, completed_at	One actionable work item for a stage.
StageAction	action, reason, candidate scope, decision payload	Business action that closes/returns a task; also represented in audit.

7.2 Secondment State Machine

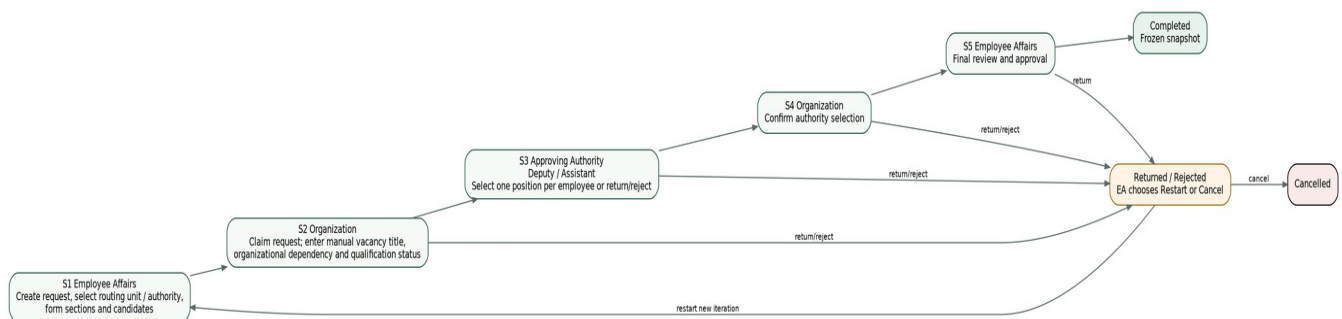


Figure note: the approval stage resolves through ApprovingAuthorityAssignment; the responsible person may be a Deputy or Assistant and may cover multiple routing units.

Figure 4 - secondment state machine.

7.3 Promotion State Machine

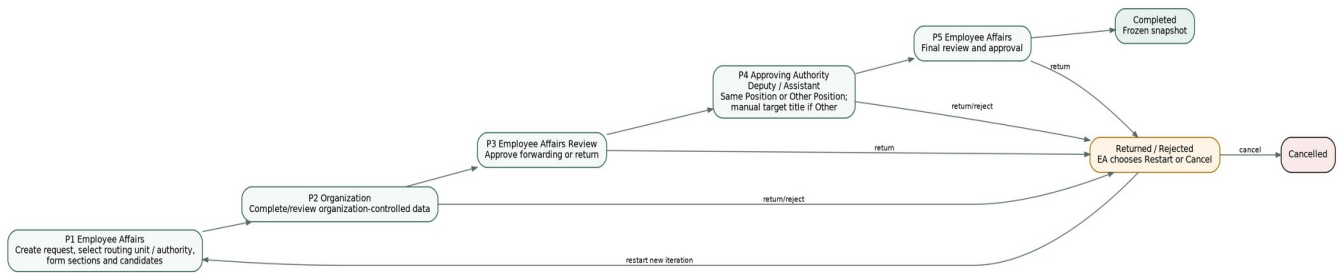


Figure note: the approval stage resolves through ApprovingAuthorityAssignment and uses the frozen request authority snapshot.

Figure 5 - promotion state machine.

7.4 Restart Implementation

- A return/reject closes the current StageTask and marks the iteration Returned.
- The original Employee Affairs user receives an actionable “Returned” view containing reason and previous timeline.
- Restart creates WorkflowIteration N+1 and a new Employee Affairs StageTask. Candidate data may be copied forward as an editable starting point, but prior rows/decisions are never updated.
- Cancel closes the request with Cancelled status and no further active tasks.
- Recall is implemented as an Employee Affairs initiated return/restart event on a non-final active iteration.

8. PostgreSQL Data Architecture

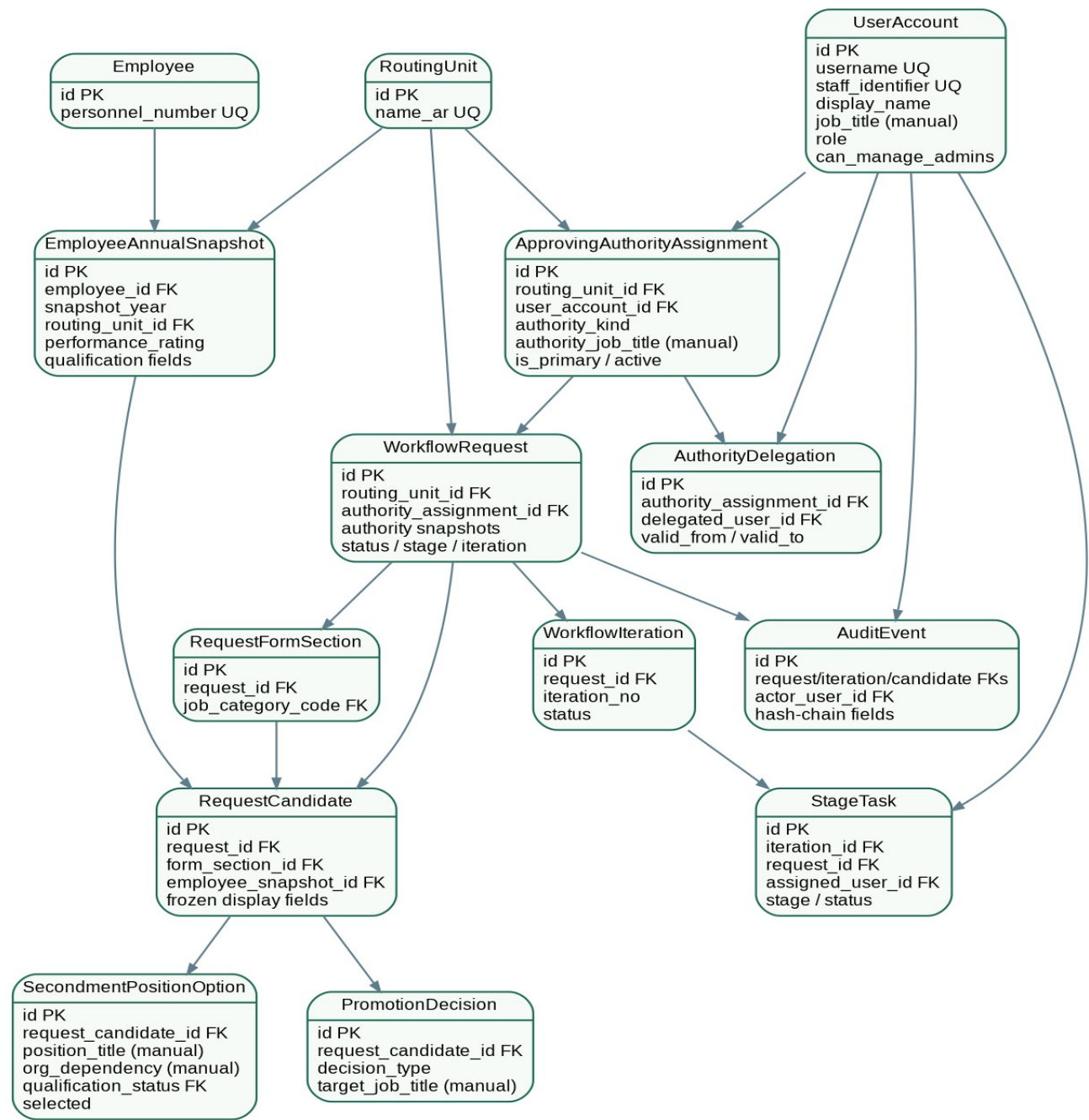


Figure note: this v1.5 model separates routing units from authority persons/accounts and includes RequestFormSection for the supplied form subsection drop-down.

Figure 6 - simplified logical data model.

8.1 Identity vs Annual Snapshot

Personnel Number is treated as the stable business identifier for Employee. Annual data is stored in a separate immutable EmployeeAnnualSnapshot keyed by year and Personnel Number. This prevents the common failure mode where importing the next year's spreadsheet changes the data shown in an already-approved 2026 request.

Example	Meaning
Employee 12656	Stable identity row; one per Personnel Number.

Example	Meaning
Snapshot (2026,12656)	The 2026 name/job/department/performance/qualification values.
Snapshot (2027,12656)	The new annual values, imported later; does not overwrite 2026.
RequestCandidate -> 2026 snapshot	Request points to the exact annual HR context used when the request was created.
RoutingUnit -> AuthorityAssignment	Admin manually maps one active primary Approving Authority user to each routing unit. The same user may cover multiple routing units if explicitly configured.
WorkflowRequest -> AuthorityAssignment snapshot	A request freezes the selected authority staff identifier, display name, manually entered descriptive job title and authority kind so later staffing changes do not rewrite history.
RequestFormSection	Groups candidates under one approved target/form job-category subsection for screen and PDF rendering.

8.2 Request Snapshot Strategy

- RequestCandidate references the annual snapshot and also stores final display snapshot fields required to make completed requests self-contained.
- Decision tables store manual Organization/Approving Authority values separately from employee master data.**
- Finalization does not mutate the annual snapshot or employee master; it freezes workflow-owned fields only.

8.3 Indexing

- Employee(personnel_number) UNIQUE.
- EmployeeAnnualSnapshot(snapshot_year, personnel_number) UNIQUE; indexes on mapped routing unit and current job category.**
- WorkflowRequest(department_id, status, current_stage, created_at) plus created_by index.
- StageTask(stage_code, status, assigned_user_id) and partial index for unassigned Organization tasks.
- RequestCandidate(request_id, employee_snapshot_id).
- AuditEvent(request_id, created_at, actor_user_id, routing-unit/request-date access paths.**
- Notification(recipient_user_id, read_at, created_at).

Authority routing model: RoutingUnit is separate from UserAccount. ApprovingAuthorityAssignment directly links a routing unit to an active manually created Approving Authority application user with authority_kind, descriptive job title/effective status and configuration history. A partial unique constraint prevents more than one active primary assignment per routing unit, while the same user may cover several units when explicitly configured. Job-title text never grants access.

Form grouping model: RequestFormSection references one of the five approved job-category values. RequestCandidate links to a section. This reproduces the نموذج (1) subsection drop-down and provides deterministic UI/PDF grouping.

9. Annual Excel Import Architecture

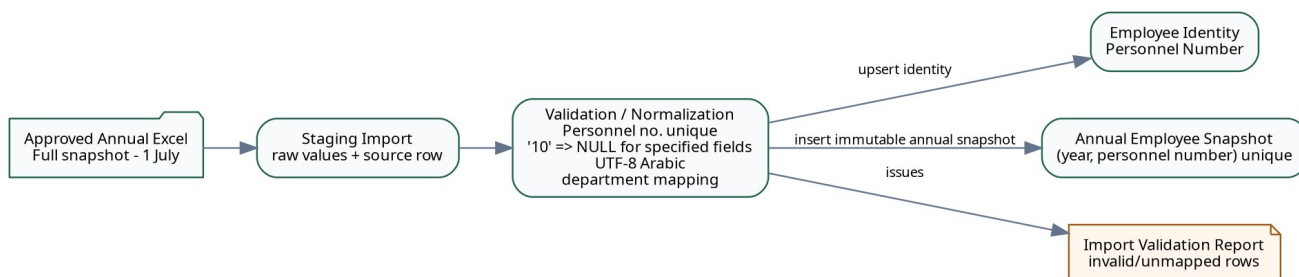


Figure 7 - annual Excel import and validation pipeline.

9.1 Current Workbook Facts

Observation	Value / Handling
Main data rows	484 employee rows in current workbook.
Personnel Number	484 populated and unique in current workbook.
Subgroup	479 "مستوى اول", 5 "مستوى ثاني"; both are accepted because the supplied snapshot is the authoritative population.
Performance	82 جيد جدا, 144 ممتاز, 198 جيد, source "10" 60 -> NULL by stakeholder rule.
Department "10"	2 rows -> NULL by stakeholder rule.
Missing qualification date	1 row is currently blank; field is nullable.
Department reference mismatch	Source workbook contains department/unit labels not present in the approved 22-item reference list; these must be mapped before workflow routing.
Operational accounts	All Employee Affairs, Organization and Approving Authority accounts are created manually by Admin; staff IDs are not hard-coded or imported into account seeds.
Approving Authority configuration	Admin manually enters display/job-title data and maps the account to one or more routing units. Job-title text is descriptive only and never grants access.

9.2 Import Validation Rules

- Reject batch activation if duplicate Personnel Numbers exist within the snapshot.
- Normalize blank strings, "-----" only where configured, and stakeholder-defined "10" sentinel values without changing raw staging values.
- Preserve original row number and original raw values for troubleshooting.
- Validate/convert qualification dates; invalid dates remain an import issue instead of guessed values.
- **Resolve source department -> approved RoutingUnit mapping. Unmapped rows are not available for request creation until mapped.**
- Generate an import summary: total rows, accepted, warning, blocked, duplicate, unmapped and activated snapshot year.

10. Authentication and Security

10.1 Local Authentication v1

- UserAccount stores username, manually entered staff identifier/display name, optional descriptive job title, role, Argon2id password hash, active flag and must_change_password. Except for the first bootstrap Admin, operational accounts are created manually through AdminService and are never seeded from staff spreadsheets.
- Login verifies password, active/delegation state and creates a server-managed authenticated session.
- Browser receives only an opaque session identifier cookie; password hashes and internal authorization metadata never reach the client.
- Logout/password reset/account deactivation revokes active sessions for that account.
- Failed authentication attempts are rate-limited/temporarily locked and logged.

10.2 CAP User Mapping

Custom authentication middleware resolves the local session and sets the CAP user identity/roles used by CAP authorization. This creates a clean future migration path: an AD/OIDC provider can later replace the local authenticator while leaving most business authorization handlers unchanged.

10.3 Audit Integrity

- AuditEvent is append-only at service/API level and database permissions deny normal UPDATE/DELETE.
- Each event stores previous_hash and event_hash over canonical event fields, creating a tamper-evident chain. SHA-256 is suitable here for integrity; it is not used for passwords.
- The audit actor snapshot includes account ID, display name and role at event time so later account deactivation/rename does not destroy historical meaning.
- No public Admin registration endpoint is permitted. The first privileged Admin is created by a one-time controlled bootstrap command. Only an Admin with Manage Admins may create/manage another Admin, and the last active privileged Admin cannot be deactivated.
- Approving Authority authorization is derived from active manually configured ApprovingAuthorityAssignment and delegation records, not from job-title text, spreadsheet classification or a single department field embedded in the account. This supports one authority covering multiple routing units without over-broad access.

11. Audit, Notifications and PDF

11.1 Audit Event Envelope

Field	Description
event_id	UUID.
request_id / iteration_id	Workflow scope.
candidate_id	Optional when action affects one employee.
actor_user_id + actor_name_snapshot	Who performed the action.
actor_role_snapshot	Role at event time.
action_code	CREATE, SUBMIT, CLAIM, APPROVE, REJECT, RETURN, RECALL, RESTART, CANCEL, FINAL_APPROVE, PDF_GENERATE, ACCOUNT_* etc.
from_stage / to_stage	Workflow transition.
reason	Required for exception actions.
metadata_json	Safe structured decision/diff details, including routing/authority assignment identifiers when relevant.
created_at	Server timestamp.
previous_hash / event_hash	Tamper-evident chain.

11.2 Notification Delivery

- Notifications are persisted in PostgreSQL and loaded by polling/refresh; WebSocket/SSE is optional, not necessary for v1 correctness.
- **The recipient logic is event-driven: originating EA on returns, all relevant Organization users on an unassigned stage, the responsible Approving Authority on Approving Authority stage, and the claimant/owner on subsequent actions.**
- Unread counts are UI convenience; audit history is the authoritative record.

11.3 PDF Generation

- Backend builds a normalized document view model from frozen request/decision data and approval summary.
- HTML/CSS templates use RTL, Noto Sans Arabic/Noto Kufi Arabic and A4 landscape for large tables.
- Controlled Chromium prints the HTML to PDF. Generated binary can be streamed to the user rather than permanently stored; a PdfGenerationLog stores document type, scope, template version and SHA-256 file hash.

- Audit-log PDFs accept request scope or department + predefined period (daily, weekly, monthly, quarterly, half-yearly, yearly).

12. API/Service Boundaries

Operation	Suggested Boundary / Action
Login / logout / password change	POST /auth/login, POST /auth/logout, POST /auth/change-password
My context	GET /auth/me
Create request	WorkflowService Requests + custom submit action; accepts validated routingUnitId, approvingAuthorityAssignmentId and form sections.
Employee lookup	WorkflowService employeeSnapshots lookup by year/personnel number
Organization claim	action claimRequest(requestId) using compare-and-set transaction
Secondment options	candidate child entities + submitOrganizationStage action
Approving Authority decision	action submitApproving AuthorityDecision(requestId, decisions[])
Return/reject/recall/restart/cancel	Explicit custom actions; not generic status PATCHes.
Final approve	action finalApprove(requestId)
Notifications	Notification entity with markRead action
Final PDF	ReportingService generateFinalForm(requestId)
Audit PDF	ReportingService generateAuditReport(scope, period)
Admin users/authority routing	AdminService protected CRUD/actions for users, routing units, manual Approving Authority mappings/job titles and delegations.
Routing reference	GET /reference/routing-units; GET /reference/approving-authorities? routingUnitId=...; GET /reference/form-sections
Authority decision	action submitAuthorityDecision(requestId, decisions[])

API rule: Do not expose a generic client-writable “status” field. All state changes go through named business actions so validation, authorization, audit and notifications cannot be bypassed.

13. Deployment Architecture

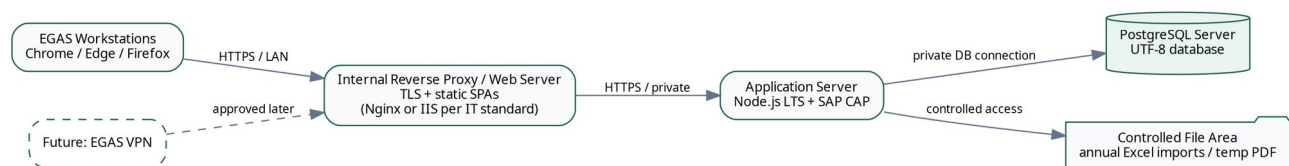


Figure 8 - internal deployment topology with future VPN path.

13.1 Recommended Production Shape

- Internal reverse proxy/web server serves the two compiled SPAs and forwards API/auth requests to the Node/CAP service.
- CAP runs as a managed Node.js service/process on an internal application server. Docker can be used if EGAS IT approves it, but the application does not require containers.
- PostgreSQL should use a private network path and a least-privilege application database user. A separate DB server is preferred when infrastructure allows.
- The approved annual employee .xlsx file is passed directly to the repository-controlled import command. The importer reads the workbook, stages raw rows, validates/normalizes/maps them, presents a summary and activates the

selected year. Database GUIs such as pgAdmin/DBBeaver are optional inspection tools only and are not required for repeatable imports.

- HTTPS/TLS terminates at the reverse proxy; internal application traffic is private and can also be TLS-protected according to IT standard.

13.2 Environments

Environment	Data / Purpose
Development	Synthetic or approved sample data; developer-local PostgreSQL; local authentication.
Test/UAT	Controlled EGAS test server; masked/approved snapshot; stakeholder workflow and PDF acceptance.
Production/Pilot	Internal EGAS server and real annual snapshot after IT/security approval.

Repository/pilot portability: the laptop pilot is reconstructed from (1) private Git repository clone, (2) machine-local .env/secrets, and (3) PostgreSQL backup/restore or the same repository-controlled annual .xlsx import. Runtime API/frontend/backend/import source is not intentionally omitted from Git; only secrets and real HR operational data are machine-local.

14. Performance and Reliability

- PostgreSQL indexes target Personnel Number lookup and stage/department queues; all list APIs paginate.
- The architecture avoids distributed services and external network dependencies, which makes sub-second LAN lookup realistic for the current data volume.
- Organization claim uses a single transaction with a conditional UPDATE/row lock; the UI must handle “already claimed by X” as a normal concurrency result.
- PDF/report generation runs outside the workflow-state transaction and may be queued if future report volume grows.
- Health checks validate process and database readiness. Central logs should include request correlation IDs without sensitive secrets.
- Backup/restore and DR are deployment concerns to be finalized by EGAS IT before production; database schema supports conventional pg_dump/enterprise backup tools.

15. Future Integration Paths

Future Change	Prepared Boundary
Active Directory / SSO	Replace LocalAuthProvider with OIDC/AD/approved gateway; retain application roles and routing-unit authority assignments or map compatible corporate groups.
SAP employee data API	Replace/augment ExcelEmployeeDataProvider with approved API adapter; still materialize annual/transaction snapshots before workflow use.
VPN remote access	Network change only; application remains internal HTTPS.
Email notifications	Implement NotificationChannel provider; in-app remains the system-of-record notification.
More workflows	Add workflow definition/module while reusing Request/Iteration/Stage/Audit infrastructure; do not hard-code all UI to only one state sequence.
English UI	Add translation resources and LTR layout; domain data remains Arabic-capable.

16. Implementation Structure

Suggested monorepo layout:

```

/AGENTS.md    Codex/developer guardrails and source precedence
/README.md    developer setup/build/test
/PILOT_SETUP.md Windows PC/laptop runbook
/.env.example config names only; no secrets
/apps

```

```

/workflow-web  React + TypeScript + UI5
/admin-web    React + TypeScript + UI5
/services/cap-api
/db           CDS entities + migrations/seeds
/srv          CAP services/actions
/lib/auth     local auth/session + Admin bootstrap
/lib/workflow state machine + transition policies
/lib/import   annual employee XLSX staging/validation/activation
/lib/routing  RoutingUnit + AuthorityAssignment resolution
/lib/audit   append-only/hash chain
/lib/pdf      form/audit PDF models/templates
/packages
/shared-types
/ui
/scripts
  setup / db-migrate / bootstrap-admin / import-annual-snapshot
  pilot-check / pilot / db-backup / db-restore / verify-audit-chain
/docs/requirements
  SRS.pdf / Architecture.pdf
/docs/handoff
  CODEX_IMPLEMENTATION_PROMPT.md
/design/stitch
  DESIGN.md + approved role screen exports
/tests
  synthetic fixtures

```

16.1 CAP Domain Packaging

- Keep account/auth entities separate from HR snapshot and workflow entities.
- Use explicit custom actions for workflow transitions rather than exposing status fields as general CRUD.
- Generate TypeScript types/clients from CAP service metadata where practical to keep frontend/backend contracts aligned.
- Maintain database schema and the direct .xlsx annual import script in the same repository so parsing, normalization, staging and activation rules are versioned with the application.

17. Architecture Decision Records

ADR	Decision	Reason
ADR-001	Modular monolith, not microservices	Tightly coupled workflow, small enterprise scale, simplest internal operations.
ADR-002	React + UI5 Web Components	Standalone React while keeping Fiori-aligned enterprise controls, RTL and accessibility support.
ADR-003	SAP CAP Node.js/TypeScript backend	Selected backend stack; strong domain/service model and PostgreSQL adapter support.
ADR-004	Two SPAs: Workflow + Admin	Separate Admin UX while avoiding three more independent role deployments.
ADR-005	PostgreSQL identity + immutable annual snapshots	Allows annual updates without changing old decisions.
ADR-006	Local authentication v1 with provider boundary	Stakeholder confirmed no AD now; keeps future SSO possible.
ADR-007	Iteration-based workflow history	Return/restart begins at start without deleting past approvals/actions.
ADR-008	Append-only tamper-evident audit	Meets complete/immutable audit requirement and protects long-term history.
ADR-009	PDF generated on demand from frozen data	Allows corrections before final approval but guarantees stable completed output.
ADR-010	Controlled annual import through staging	Protects workflow from malformed Excel and provides repeatable operations.

ADR	Decision	Reason
ADR-011	Privileged Admin bootstrap + Manage Admins permission	Avoids unauthenticated Admin sign-up, supports controlled Admin creation and preserves at least one privileged Admin.
ADR-012	Manual operational accounts and authority mapping	Staff identifiers are known, but authority job-title wording is inconsistent. Manual Admin configuration is simpler and safer than inferring identity/authorization from spreadsheets.
ADR-013	Repository-owned direct XLSX annual importer	Provides repeatable validation/staging/activation on the development PC and pilot laptop; database GUIs remain optional inspection aids rather than a hidden deployment dependency.
ADR-014	RequestFormSection reference entity for printable subsections	Matches (1) نموذج job-category drop-down and supports grouping multiple candidates consistently in UI/PDF.
ADR-015	Google Stitch for UI design handoff, no runtime dependency	Speeds role-specific RTL design while production React/CAP remains self-contained.
ADR-016	Private GitHub + AGENTS.md + stable pilot scripts	Makes Codex handoff reproducible and allows complete PC-to-laptop pilot setup without committing secrets.

18. Risks and Open Items

Risk / Open Item	Mitigation
Annual employee labels and routing-unit labels require controlled mapping.	Use explicit source-to-RoutingUnit mapping; block unmapped employee rows from workflow selection.
Exact source/type of "تقرير آخر ترقية" is unknown.	Model as configurable/manual field; finalize before final-form sign-off.
Production host/container standard unknown.	Package Node/SPAs portably; choose IIS/Nginx/container during IT deployment workshop.
Production DR/backup standard not yet defined.	Pilot minimal backup accepted; production go-live checklist requires IT backup/restore decision.
Session timeout policy not formally specified.	Use configurable 30-minute idle/8-hour absolute engineering baseline until cybersecurity overrides.
Organization-controlled promotion fields are less specific than secondment fields.	Keep promotion Organization stage configurable and restrict target-position decision to Approving Authority as confirmed.
Approving Authority names/titles are not consistently derivable from supplied staff spreadsheets.	Create authority accounts manually in Admin Portal and explicitly map each routing unit; job title is descriptive input only, never an authorization rule.
Authority can cover multiple units or hold acting titles.	Use effective-dated manual assignment records and allow the same authority user on multiple units; freeze assignment details on each request.

19. References

Source and Engineering Reference Legend

Ref	Document / Standard	Use
S1	Business Requirement Document - Appraisal (6 pages)	Primary business source for workflow, roles, notifications, PDF and audit requirements.
S2	EGAS Missing Requirements Register Bilingual v0.3 - stakeholder answers	Confirmed stakeholder decisions recorded in the answer notes on pages 2-5.
S3	البيانات الاساسية (1).xlsx	Annual Arabic HR snapshot supplied for PostgreSQL import; current workbook contains 484 employee rows.

Ref	Document / Standard	Use
S4	نموذج (1).doc	Reference final promotion and secondment printable forms and required table fields.
S5	Mom's Cloud Kitchen SRS v2.1 Revised	Structure/style reference only; no food-ordering business requirements are carried into EGAS.
E1	SAP CAP - PostgreSQL guide	Engineering reference for @cap-js/postgres and CAP persistence.
E2	SAP CAP - Authentication / Authorization guides	Engineering reference for CAP user/role authorization boundaries.
E3	UI5 Web Components documentation	Engineering reference for Fiori-aligned React UI components, RTL and accessibility.
E4	OWASP Password Storage Cheat Sheet	Engineering reference for Argon2id / salted adaptive password hashing.
E5	W3C WCAG 2.2	Accessibility baseline; stakeholder requested Level AA.
S6	النواب والمساعدین.xlsx	Reference-only staff workbook. Inconsistent/mixed titles are not used to auto-create accounts or infer authorization.
S7	Stakeholder follow-up - 15 Aug 2026	Confirmed manual operational account creation and explicit Approving Authority configuration because supplied job-title wording is not reliably consistent.
S8	Google Stitch design handoff decision	Approved design-time source for all v1 logins, dashboards and core workflows; synthetic data only.
S9	GitHub/Codex handoff decision	Complete cloneable runtime repository, AGENTS.md, requirements/design assets and stable pilot commands.

Engineering links: <https://cap.cloud.sap/docs/guides/databases/postgres> ; <https://cap.cloud.sap/docs/guides/security/authorization> ; <https://ui5.github.io/webcomponents/> ; https://cheatsheetseries.owasp.org/cheatsheets/Password_Storage_Cheat_Sheet.html ; <https://www.w3.org/TR/WCAG22/>

20. Repository, Stitch and Pilot Handoff

Codex shall receive the latest SRS PDF, latest Architecture PDF, approved Stitch UI/screens, DESIGN.md or equivalent design rules, the versioned implementation prompt and AGENTS.md. SRS business rules/permissions are authoritative; Architecture controls technical boundaries; Stitch controls approved visual/interaction intent only where compatible with the specifications.

The private GitHub repository contains all runtime frontend/backend/API source, CAP database model/migrations, data importers, routing configuration code, PDF/audit generation, tests and operational scripts. It excludes real passwords, session/database secrets, real HR Excel files, database backups and generated employee documents.

Stable command	Purpose
npm install	Install dependencies.
npm run setup	Validate prerequisites and initialize local configuration safely.
npm run db:migrate	Apply repository schema/migrations to PostgreSQL.
npm run admin:bootstrap	Create first privileged Admin if needed.
npm run data:import -- --file <xlsx> --year <YYYY>	Stage/validate/activate annual eligible employee snapshot.
npm run pilot:check	Check env, DB/schema, privileged Admin, active annual snapshot, 22 routing units, authority assignment coverage and ports.
npm run pilot	Start CAP backend + Workflow Portal + Admin Portal for local pilot.
npm run db:backup -- --file <path>	Create controlled PostgreSQL backup.

`npm run db:restore -- --file <path>`

Restore controlled PostgreSQL backup with safeguards.

`npm test / npm run lint / npm run build`

Quality gates before pilot/release.

Laptop portability is intentionally independent of external APIs for v1: clone code from Git, create the local `.env` from `.env.example`, restore/import PostgreSQL data, run `pilot:check`, then run `pilot`. API implementation code is present in the repository; only secrets/configuration values are machine-local.

21. Security Hardening Architecture (v1.6)

This section makes the SRS security controls concrete for the React + UI5 + SAP CAP Node.js + PostgreSQL architecture and the private GitHub/Codex delivery model.

21.1 Security Request Pipeline

- Every protected request flows: reverse proxy/TLS -> session resolution -> CSRF/origin checks for state changes -> rate limiting where relevant -> CAP authentication context -> role/object/routing-unit authorization -> DTO validation -> business/state-transition validation -> parameterized persistence -> audit/security logging -> response projection.
- The frontend is never trusted to supply authoritative role, actor, workflow stage, ownership, routing unit, annual snapshot value or approval identity.
- The API follows deny-by-default behavior: no matching authorization rule means no access.

21.2 Secrets and Git Lifecycle

- Runtime secrets live in machine-local .env for development/pilot or EGAS-approved secret storage in production. .env is gitignored; .env.example contains placeholders only.
- No VITE_* or other browser-exposed build variable may contain a secret. The frontend API URL is configuration, not a credential.
- Add repository commands: npm run security:secrets (secret scan), npm run security:scan (dependency/static checks), npm run security:check (aggregate release gate).
- Enable GitHub secret scanning/push protection when available and run a local/CI scanner regardless of GitHub plan.
- Leak procedure: revoke/rotate immediately -> update runtime configuration -> rewrite/purge Git history with an approved tool such as git-filter-repo -> force-update affected refs if needed -> rescan -> record incident. History cleanup never substitutes for rotation.

21.3 Authentication and Session Design

- Argon2id hashes are stored in user_account.password_hash. Passwords are never encrypted for later recovery and never hashed with raw SHA-256.
- auth_session stores only a hash of the opaque browser session token, expiration metadata, revocation state and minimal diagnostic metadata. The raw token exists only in the Secure/HttpOnly browser cookie and transient request processing.
- Use per-session CSRF secret/token material or an equivalent double-submit/origin-validated strategy for state-changing browser requests.
- Rotate the session after authentication and privilege-sensitive changes. Revoke sessions on logout, password reset/change, account deactivation and role/authority changes where continued authorization is unsafe.
- Engineering timeout defaults: 30-minute idle and 8-hour absolute session lifetime, configurable by environment/EGAS IT.
- Login rate limiter keys on normalized account identifier plus source IP. Engineering baseline: 5 failures in 10 minutes -> 15-minute account lock. Generic failure messages avoid username enumeration.
- Bot protection is progressive and local-capable: throttling/lockout first; optional challenge only when configured by IT. The offline stakeholder pilot must not require an external CAPTCHA service.

21.4 Authorization, Object Scope and Field Integrity

- CAP custom actions are used for workflow transitions. Generic CRUD writes to status/current_stage/actor/approver fields are not exposed.
- Each service method computes scope from the authenticated CAP user plus database state: Employee Affairs creator/returned ownership, Organization stage/claim, ApprovingAuthorityAssignment/delegation, Admin privilege and routing-unit scope.
- Use explicit input DTOs and response DTOs. Reject unknown input properties at sensitive endpoints. Derive protected fields server-side.
- Organization claim uses one conditional UPDATE in a transaction (or SELECT ... FOR UPDATE equivalent) and returns HTTP 409/typed conflict when already claimed.
- Use version columns/ETags or equivalent optimistic concurrency on mutable workflow/admin configuration records so stale forms cannot silently overwrite newer state.

21.5 PostgreSQL Least Privilege and RLS

- Use separate database roles for schema migration/ownership and runtime application access. The runtime role is not superuser, does not own protected tables and has no BYPASSRLS.
- PostgreSQL is reachable only from approved backend/admin infrastructure; no browser/client DB connections exist.
- For RLS-capable tables, CAP begins a transaction and sets transaction-local identity context (for example egas.user_id, egas.role, egas.routing_unit_ids or an equivalent safe mechanism). RLS policies reference only trusted transaction-local values set by the backend.
- Enable RLS where row scope is stable and testable. Do not force a brittle RLS policy onto tables whose access is primarily a complex state-machine action until the policy can be verified. Backend authorization remains mandatory in all cases.
- Audit tables use restrictive privileges; normal runtime code gets INSERT/SELECT as required but not arbitrary UPDATE/DELETE.

21.6 SQL, Validation, XSS and Response Shaping

- CAP/CDS query APIs are preferred. Any raw SQL must use parameters/bind variables; string concatenation of untrusted input is prohibited.
- Central validation schemas enforce type, format, max length, enum, date range, pagination and per-action business constraints for bodies, paths and query parameters.
- React/UI5 renders user-controlled text as text, not HTML. dangerouslySetInnerHTML or direct DOM HTML insertion with user data is prohibited unless reviewed and sanitized through an approved allow-list sanitizer.
- Response projections expose only required fields. Service entities carrying password_hash, session metadata, internal privilege fields or unnecessary HR columns are not directly serialized to clients.
- Configure safe body/query/pagination/report-size limits and return structured 400/413/429 errors as appropriate.
- Production error middleware returns safe messages + correlation ID; stack traces/SQL/filesystem internals are logged only on the server with secret filtering.

21.7 Annual XLSX Import Security

- The importer reads .xlsx directly using the repository-owned parser. Accept only approved .xlsx; reject .xlsm/macro-enabled or unrelated file types.
- Validate file extension plus ZIP/XLSX container signature/structure, maximum size, expected worksheet/header schema and bounded row count before parsing all data.
- Use server-controlled temporary paths/filenames outside public web roots, restricted file permissions and cleanup after import/validation according to policy.
- Excel data is untrusted: keep raw staging rows, validate/normalize, map routing units and activate only a validated full annual snapshot. Spreadsheet formulas/macros are never executed by the application.
- Operational users do not receive a generic attachment upload feature in v1.

21.8 HTTPS, Reverse Proxy and Browser Headers

- Allow HTTP only for isolated localhost development. Stakeholder pilot/production-like internal access uses HTTPS where feasible; production requires HTTPS.
- Reverse proxy terminates TLS, redirects/rejects HTTP and adds HSTS only after HTTPS is confirmed. Backend trusts forwarded headers only from the known proxy.
- Baseline response headers: Content-Security-Policy; X-Content-Type-Options: nosniff; CSP frame-ancestors (plus compatibility X-Frame-Options if required); Referrer-Policy; Permissions-Policy; HSTS on HTTPS deployment.
- CSP should prefer self-hosted scripts/styles/fonts and avoid unsafe-eval/unsafe-inline. Any exception is documented and minimized.
- CORS lists exact Workflow/Admin origins, methods and headers. No wildcard origin with credentialed requests.

21.9 Encryption and Backup Architecture

- Use TLS for browser-to-proxy and production backend-to-database traffic when required/available within EGAS infrastructure.
- Use OS/storage/database-volume encryption and encrypted backup storage according to EGAS infrastructure standards. Restrict backup access and transfer; backups remain outside Git.

- If application-level encryption is later required for specific stored fields, use authenticated encryption with keys from secret management and key rotation procedures. Do not add application crypto without a defined data classification/use case.
- Password hashing remains one-way and separate from encryption-at-rest controls.

21.10 Security Events, Audit and Monitoring

- Create a dedicated security_event stream/table or equivalent protected log for authentication, logout, session revocation, denied authorization, privileged account operations, authority mapping/delegation changes, import activation/failure and security configuration changes.
- Business audit_event remains append-only/tamper-evident and references request/actor context. Security logs may reference the same correlation/request IDs but do not replace the legal/business audit trail.
- Logging middleware redacts cookies, Authorization headers, passwords, CSRF tokens, database credentials, encryption keys and sensitive request bodies before writing logs.

21.11 CI, Codex and Repository Release Gates

- AGENTS.md instructs Codex never to introduce secrets, client-side authorization shortcuts, raw SQL concatenation, unsafe HTML rendering, generic status PATCH endpoints or direct browser DB access.
- package-lock.json is committed. CI/pilot setup uses reproducible installation (npm ci where appropriate).
- npm run security:secrets scans repository/history/worktree as configured; npm run security:scan runs dependency/static checks; npm run security:check runs the release security gate. npm run pilot:check includes the minimum checks required to safely demo.
- High/critical reachable dependency vulnerabilities, detected real secrets or failing authorization/security tests block a release unless explicitly documented and risk-accepted.
- Debug servers, verbose stack traces and unrestricted API/database consoles are disabled in pilot/production mode.

21.12 Verification Target

- Automated tests cover the role x object x stage authorization matrix, IDOR attempts, mass assignment, stale-write conflict, SQL injection, XSS/output encoding, CSRF, rate limiting, session rotation/revocation, invalid/oversized XLSX, CORS/security headers, RLS policies where enabled and safe error responses.
- Use OWASP ASVS 5.0 Level 2 as the production-intended verification target with explicit Not Applicable rationale where needed.
- Before production with real HR workflow data, EGAS IT/Cybersecurity reviews TLS, secrets, network/database privileges, RLS configuration, backups, dependency findings and penetration/security assessment results according to corporate policy.

21.13 Additional Stable Commands

The implementation handoff shall require Codex to create these commands in addition to the existing setup/pilot/database commands:

```
npm run security:secrets
npm run security:scan
npm run security:check
```

Command internals may evolve, but the user-facing command names remain stable and are documented in README.md / PILOT_SETUP.md.